

RESTRICTED

ETHICAL HACKING NOTE

ETHICAL HACKING

Hacking has been a part of computing for almost five decades and it is a very broad discipline, which covers a wide range of topics. The first known event of hacking had taken place in 1960 at MIT and at the same time, the term "Hacker" was originated.

Hacking is the act of finding the possible entry points that exist in a computer system or a computer network and finally entering into them. Hacking is usually done to gain unauthorized access to a computer system or a computer network, either to harm the systems or to steal sensitive information available on the computer.

Hacking is usually legal as long as it is being done to find weaknesses in a computer or network system for testing purpose. This sort of hacking is what we call **Ethical Hacking**.

A computer expert who does the act of hacking is called a "Hacker". Hackers are those who seek knowledge, to understand how systems operate, how they are designed, and then attempt to play with these systems.

Types of Hacking

We can segregate hacking into different categories, based on what is being hacked. Here is a set of examples:

Website Hacking – Hacking a website means taking unauthorized control over a web server and its associated software such as databases and other interfaces.

Network Hacking – Hacking a network means gathering information about a network by using tools like Telnet, NS lookup, Ping, Tracert, Netstat, etc. with the intent to harm the network system and hamper its operation.

Email Hacking – It includes getting unauthorized access on an Email account and using it without taking the consent of its owner.

Ethical Hacking – Ethical hacking involves finding weaknesses in a computer or network system for testing purpose and finally getting them fixed.

Password Hacking – This is the process of recovering secret passwords from data that has been stored in or transmitted by a computer system.

Computer Hacking – This is the process of stealing computer ID and password by applying hacking methods and getting unauthorized access to a computer system.

Advantages of Hacking

Hacking is quite useful in the following scenarios –

- To recover lost information, especially in case you lost your password.
- To perform penetration testing to strengthen computer and network security.
- To put adequate preventative measures in place to prevent security breaches.
- To have a computer system that prevents malicious hackers from gaining access.

Disadvantages of Hacking

- Hacking is quite dangerous if it is done with harmful intent. It can cause.
- Massive security breach.
- Unauthorized system access on private information.
- Privacy violation.
- Hampering system operation.
- Denial of service attacks.
- Malicious attack on the system.

Purpose of Hacking

There could be various positive and negative intentions behind performing hacking activities. Here is a list of some probable reasons why people indulge in hacking activities:

- Just for fun.
- Show-off.
- Steal important information.
- Damaging the system.
- Hampering privacy.
- Money extortion.
- System security testing.
- To break policy compliance.
- Monitoring an Extra marital affairs.

Types of Hacker

Hackers can be classified into different categories such as white hat, black hat, and grey hat, based on their intent of hacking a system. These different terms come from old Spaghetti Westerns, where the bad guy wears a black cowboy hat and the good guy wears a white hat.

White Hat Hackers

White Hat hackers are also known as **Ethical Hackers**. They never intent to harm a system, rather they try to find out weaknesses in a computer or a network system as a part of penetration testing and vulnerability assessments. Ethical hacking is not illegal and it is one of the demanding jobs available in the IT industry. There are numerous companies that hire ethical hackers for penetration testing and vulnerability assessments.

Black Hat Hackers

Black Hat hackers, also known as **crackers**, are those who hack in order to gain unauthorized access to a system and harm its operations or steal

sensitive information. Black Hat hacking is always illegal because of its bad intent which includes stealing corporate data, violating privacy, damaging the system, blocking network communication, etc.

Grey Hat Hackers

Grey hat hackers are a blend of both black hat and white hat hackers. They act without malicious intent but for their fun, they exploit a security weakness in a computer system or network without the owner's permission or knowledge. Their intent is to bring the weakness to the attention of the owners and getting appreciation or a little bounty from the owners.

Miscellaneous Hackers

Apart from the above well-known classes of hackers, we have the following categories of hackers based on what they hack and how they do it.

Red Hat Hackers

Red hat hackers are again a blend of both black hat and white hat hackers. They are usually on the level of hacking government agencies, top-secret information hubs, and generally anything that falls under the category of sensitive information.

Blue Hat Hackers

A blue hat hacker is someone outside computer security consulting firms who is used to bug-test a system prior to its launch. They look for loopholes that can be exploited and try to close these gaps. Microsoft also uses the term **BlueHat** to represent a series of security briefing events.

Elite Hackers

This is a social status among hackers, which is used to describe the most skilled. Newly discovered exploits will circulate among these hackers.

Script Kiddie

A script kiddie is a non-expert who breaks into computer systems by using pre-packaged automated tools written by others, usually with little understanding of the underlying concept, hence the term **Kiddie**.

Neophyte

A neophyte, "n00b", or "newbie" or "Green Hat Hacker" is someone who is new to hacking or phreaking and has almost no knowledge or experience of the workings of technology and hacking.

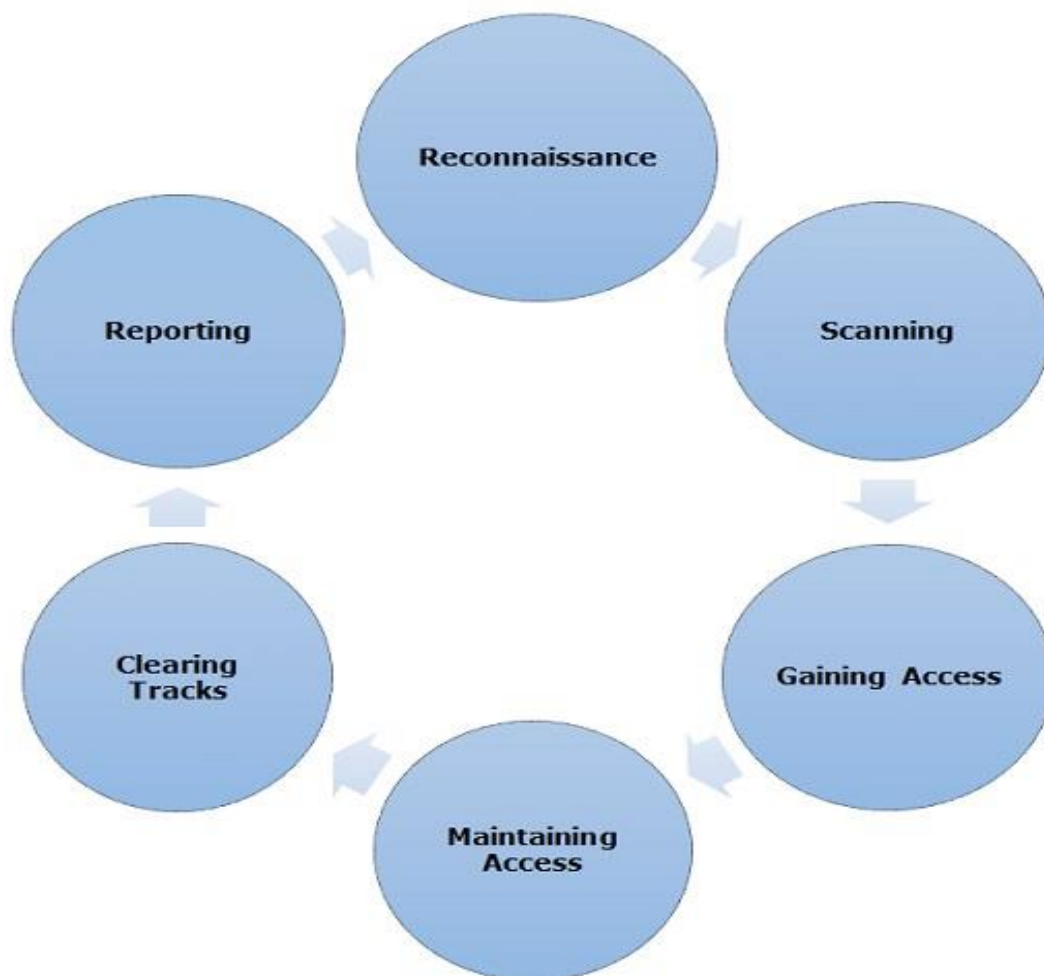
Hacktivist

A hacktivist is a hacker who utilizes technology to announce a social, ideological, religious, or political message. In general, most hacktivism involves website defacement or denialof-service attacks.

Ethical Hacking Process

Like all good projects, ethical hacking too has a set of distinct phases. It helps hackers to make a structured ethical hacking attack.

Different security training manuals explain the process of ethical hacking



in different ways, but for me as an Ethical Hacker, the entire process can be categorized into the following six phases.

Reconnaissance

Reconnaissance is the phase where the attacker gathers information about a target using active or passive means. The tools that are widely used in this process are NMAP, Hping, Maltego, and Google Dorks.

Reconnaissance takes place in two parts which are:

Active Reconnaissance and **Passive Reconnaissance**.

Active Reconnaissance

In this process, you will directly interact with the computer system to gain information. This information can be relevant and accurate. But there is a risk of getting detected if you are planning active reconnaissance without permission. If you are detected, then system admin can take severe action against you and trail your subsequent activities.

Passive Reconnaissance

In this process, you will not be directly connected to a computer system. This process is used to gather essential information without ever interacting with the target systems.

Footprinting is a part of reconnaissance process which is used for gathering possible information about a target computer system or network. Footprinting could be both **passive** and **active**. Reviewing a company's website is an example of passive footprinting, whereas attempting to gain access to sensitive information through social engineering is an example of active information gathering.

Scanning

In this process, the attacker begins to actively probe a target machine or network for vulnerabilities that can be exploited. The tools used in this process are Nessus, Nexpose, and NMAP.

Gaining Access

In this process, the vulnerability is located and you attempt to exploit it in order to enter into the system. The primary tool that is used in this process is Metasploit.

Maintaining Access

It is the process where the hacker has already gained access into a system. After gaining access, the hacker installs some backdoors in order to enter into the system when he needs access in this owned system in future. Metasploit is the preferred tool in this process.

Clearing Tracks

This process is actually an unethical activity. It has to do with the deletion of logs of all the activities that take place during the hacking process.

Reporting

Reporting is the last step of finishing the ethical hacking process. Here the Ethical Hacker compiles a report with his findings and the job that was done such as the tools used, the success rate, vulnerabilities found, and the exploit processes.

Quick Tip

The processes are not standard. You can adopt a set of different processes and tools according to your techniques that you are comfortable with. The process is of least significance as long as you are able to get the desired results.

Information Gathering and getting to know the target systems is the first process in ethical hacking. Reconnaissance is a set of processes and techniques (Footprinting, Scanning & Enumeration) used to covertly discover and collect information about a target system.

During reconnaissance, an ethical hacker attempts to gather as much information about a target system as possible, following the seven steps listed below:

- Gather initial information.
- Determine the network range.
- Identify active machines.
- Discover open ports and access points.
- Fingerprint the operating system.
- Uncover services on ports.
- Map the network.

Footprinting

Footprinting is basically the first step where hacker gathers as much information as possible to find ways to intrude into a target system or at least decide what type of attacks will be more suitable for the target. During this phase, a hacker can collect the following information

- Domain name
- IP Addresses
- Namespaces
- Employee information
- Phone numbers
- E-mails
- Job Information

In the following section, we will discuss how to extract the basic and easily accessible information about any computer system or network that is linked to the Internet.

Domain Name Information

You can use <http://www.whois.com/whois> website to get detailed information about a domain name information including its owner, its registrar, date of registration, expiry, name server, owner's contact



The image shows a screenshot of the WHOIS Lookup website. At the top, the text "WHOIS Lookup" is displayed in a large, orange, stylized font. Below this, the text "Search domain name registration records" is shown in a smaller, grey font. There is a search input field with the placeholder text "Enter Domain Name or IP Address". To the right of the input field is a green button with a magnifying glass icon and the text "SEARCH". Below the input field, there are examples of domain names: "Examples: qq.com, google.co.in, bbc.co.uk, ebay.ca".

information, etc.

Here is a sample record of www.tutorialspoint.com extracted from WHOIS Lookup.

tutorialspoint.com registry whois	Updated 2 days ago - Refresh
Domain Name: TUTORIALSPOINT.COM Registrar: GODADDY.COM, LLC Sponsoring Registrar IANA ID: 146 Whois Server: whois.godaddy.com Referral URL: http://www.godaddy.com Name Server: NS1.EDGECASTDNS.NET Name Server: NS2.EDGECASTDNS.NET Name Server: NS3.EDGECASTDNS.NET Name Server: NS4.EDGECASTDNS.NET Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited Status: clientRenewProhibited https://icann.org/epp#clientRenewProhibited Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited Updated Date: 08-apr-2016 Creation Date: 30-sep-2006 Expiration Date: 30-sep-2018	
tutorialspoint.com registrar whois	Updated 2 days ago
Domain Name: TUTORIALSPOINT.COM Registry Domain ID: 613404007_DOMAIN_COM-VRSN Registrar WHOIS Server: whois.godaddy.com Registrar URL: http://www.godaddy.com Update Date: 2009-03-19T17:57:49Z Creation Date: 2006-09-30T07:23:20Z Registrar Registration Expiration Date: 2018-09-30T07:23:20Z Registrar: GoDaddy.com, LLC Registrar IANA ID: 146 Registrar Abuse Contact Email: abuse@godaddy.com Registrar Abuse Contact Phone: +1.4806242505 Domain Status: clientTransferProhibited http://www.icann.org/epp#clientTransferProhibited Domain Status: clientUpdateProhibited http://www.icann.org/epp#clientUpdateProhibited Domain Status: clientRenewProhibited http://www.icann.org/epp#clientRenewProhibited Domain Status: clientDeleteProhibited http://www.icann.org/epp#clientDeleteProhibited Registry Registrant ID: Not Available From Registry Registrant Name: Mohammad Mohtashim Registrant Organization: Tutorial Point India Private Limited Registrant Street: Plot No 388A, Road No 22 Registrant Street: Jubilee Hills Registrant City: Hyderabad Registrant State/Province: Andhra Pradesh Registrant Postal Code: 500033 Registrant Country: IN Registrant Phone: Registrant Phone Ext: Registrant Fax:	

Quick Fix

It's always recommended to keep your domain name profile a private one which should hide the above-mentioned information from potential hackers.

Finding IP Address

You can use **ping** command at your Command prompt. This command is available on Windows as well as on Linux OS. Following is the example to find out the IP address of tutorialspoint.com

ping tutorialspoint.com

It will produce the following result –

PING tutorialspoint.com (66.135.33.172) 56(84) bytes of data.

64 bytes from 66.135.33.172: icmp_seq = 1 ttl = 64 time = 0.028 ms

64 bytes from 66.135.33.172: icmp_seq = 2 ttl = 64 time = 0.021 ms

64 bytes from 66.135.33.172: icmp_seq = 3 ttl = 64 time = 0.021 ms

64 bytes from 66.135.33.172: icmp_seq = 4 ttl = 64 time = 0.021 ms

Finding Hosting Company

Once you have the website address, you can get further detail by using ip2location.com website. Following is the example to find out the details of an IP address –

	Field Name	Value
	IP Address	49.205.122.168
☒	Country	India
☐	Region & City	Kukatpalli, Telangana
☐	Latitude & Longitude	17.48333, 78.41667
☐	ZIP Code	508126
☐	ISP	Beam Telecom Pvt Ltd
☐	Domain	beamtele.com
☐	Time Zone	+05:30

Here the ISP row gives you the detail about the hosting company because IP addresses are usually provided by hosting companies only.

Quick Fix

If a computer system or network is linked with the Internet directly, then you cannot hide the IP address and the related information such as the hosting company, its location, ISP, etc. If you have a server containing very sensitive data, then it is recommended to keep it behind a secure proxy so that hackers cannot get the exact details of your actual server. This way, it will be difficult for any potential hacker to reach your server directly.

Another effective way of hiding your system IP and ultimately all the associated information is to go through a Virtual Private Network (VPN). If you configure a VPN, then the whole traffic routes through the VPN network, so your true IP address assigned by your ISP is always hidden.

IP Address Ranges

Small sites may have a single IP address associated with them, but larger websites usually have multiple IP addresses serving different domains and sub-domains.

You can obtain a range of IP addresses assigned to a particular company using [American Registry for Internet Numbers \(ARIN\)](#).



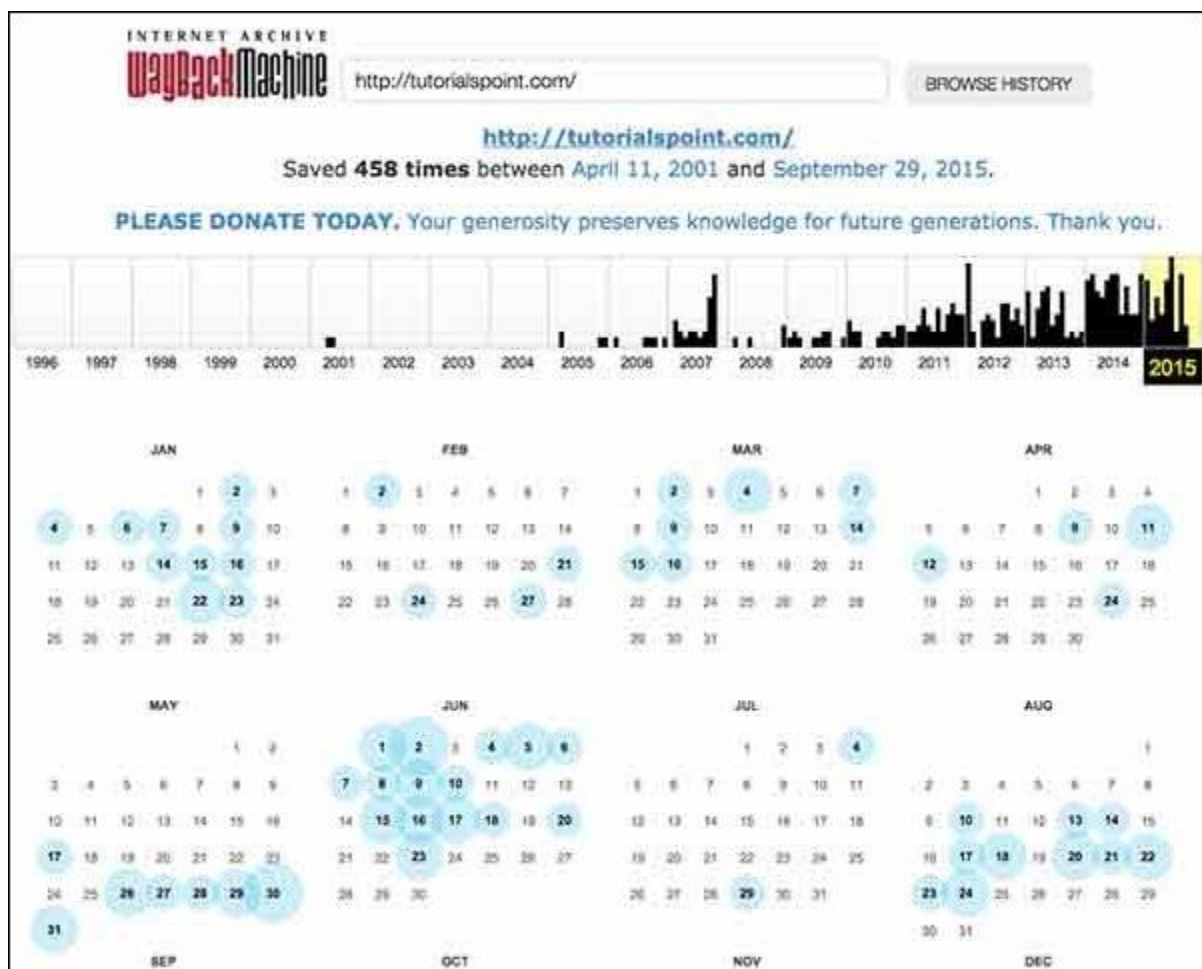
You can enter company name in the highlighted search box to find out a list of all the assigned IP addresses to that company.

History of the Website

It is very easy to get a complete history of any website using www.archive.org.



You can enter a domain name in the search box to find out how the website was looking at a given point of time and what were the pages available on the website on different dates.



Quick Fix

Though there are some advantages of keeping your website in an archive database, but if you do not like anybody to see how your website progressed through different stages, then you can request archive.org to delete the history of your website.

The term OS fingerprinting in Ethical Hacking refers to any method used to determine what operating system is running on a remote computer. This could be the following:

Fingerprinting

Active Fingerprinting – Active fingerprinting is accomplished by sending specially crafted packets to a target machine and then noting down its response and analyzing the gathered information to determine the target OS. In the following section, we have given an example to explain how you can use NMAP tool to detect the OS of a target domain.

Passive Fingerprinting – Passive fingerprinting is based on sniffer traces from the remote system. Based on the sniffer traces (such as Wireshark) of the packets, you can determine the operating system of the remote host.

We have the following four important elements that we will look at to determine the operating system –

- **TTL** – What the operating system sets the **Time-To-Live** on the outbound packet.
- **Window Size** – What the operating system sets the Window Size at.
- **DF** – Does the operating system set the **Don't Fragment** bit.
- **TOS** – Does the operating system set the **Type of Service**, and if so, at what.

By analyzing these factors of a packet, you may be able to determine the remote operating system. This system is not 100% accurate, and works better for some operating systems than others.

Basic Steps

Before attacking a system, it is required that you know what operating system is hosting a website. Once a target OS is known, then it becomes easy to determine which vulnerabilities might be present to exploit the target system.

Below is a simple **nmap** command which can be used to identify the operating system serving a website and all the opened ports associated with the domain name, i.e., the IP address.

```
Nmap -O -v tutorialspoint.com
```

It will show you the following sensitive information about the given domain name or IP address.

```
Starting Nmap 5.51 ( http://nmap.org ) at 2015-10-04 09:57 CDT
Initiating Parallel DNS resolution of 1 host.at 09:57
Completed Parallel DNS resolution of 1 host.at 09:57, 0.00s elapsed
Initiating SYN Stealth Scan at 09:57
Scanning tutorialspoint.com (66.135.33.172) [1000 ports]
Discovered open port 22/tcp on 66.135.33.172
Discovered open port 3306/tcp on 66.135.33.172
Discovered open port 80/tcp on 66.135.33.172
Discovered open port 443/tcp on 66.135.33.172
Completed SYN Stealth Scan at 09:57, 0.04s elapsed (1000 total ports)
Initiating OS detection (try #1) against tutorialspoint.com (66.135.33.172)
Retrying OS detection (try #2) against tutorialspoint.com (66.135.33.172)
Retrying OS detection (try #3) against tutorialspoint.com (66.135.33.172)
Retrying OS detection (try #4) against tutorialspoint.com (66.135.33.172)
Retrying OS detection (try #5) against tutorialspoint.com (66.135.33.172)
Nmap scan report for tutorialspoint.com (66.135.33.172)
Host is up (0.000038s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE
22/tcpopen  ssh
```

80/tcpopen http
 443/tcp open https
 3306/tcpopen mysql

TCP/IP fingerprint:

OS:SCAN(V=5.51%D=10/4%OT=22%CT=1%CU=40379%PV=N%DS=0%
 DC=L%G=Y%TM=56113E6D%P=
 OS:x86_64-redhat-linux-
 gnu)SEQ(SP=106%GCD=1%ISR=109%TI=Z%CI=Z%II=I%TS=A)OPS
 OS:(O1=MFFD7ST11NW7%O2=MFFD7ST11NW7%O3=MFFD7NNT11NW7
 %O4=MFFD7ST11NW7%O5=MFF
 OS:D7ST11NW7%O6=MFFD7ST11)WIN(W1=FFCB%W2=FFCB%W3=FFCB
 %W4=FFCB%W5=FFCB%W6=FF
 OS:CB)ECN(R=Y%DF=Y%T=40%W=FFD7%O=MFFD7NNSNW7%CC=Y%
 Q=)T1(R=Y%DF=Y%T=40%S=O%A
 OS:=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W
 =0%S=A%A=Z%F=R%O=%RD=0%
 OS:Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0
 %Q=)T6(R=Y%DF=Y%T=40%W=0%S=
 OS:A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z
 %A=S+%F=AR%O=%RD=0%Q=)U1(R=
 OS:Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RU
 CK=G%RUD=G)IE(R=Y%DFI=N%
 OS:T=40%CD=S)

If you do not have **nmap** command installed on your Linux system, then you can install it using the following **yum** command –

```
$yum install nmap
```

You can go through **nmap** command in detail to check and understand the different features associated with a system and secure it against malicious attacks.

Quick Fix

You can hide your main system behind a secure proxy server or a VPN so that your complete identity is safe and ultimately your main system remains safe.

Port Scanning

We have just seen information given by **nmap** command. This command lists down all the open ports on a given server.

PORT	STATE	SERVICE
22/tcp	open	ssh
80/tcp	open	http
443/tcp	open	https
3306/tcp	open	mysql

You can also check if a particular port is opened or not using the following command:

```
nmap -sT -p 443 tutorialspoint.com
```

It will produce the following result:

```
Starting Nmap 5.51 ( http://nmap.org ) at 2015-10-04 10:19 CDT
Nmap scan report for tutorialspoint.com (66.135.33.172)
Host is up (0.000067s latency).
PORT      STATE SERVICE
443/tcp   open  https
```

Nmap done: 1 IP address (1 host up) scanned in 0.04 seconds

Once a hacker knows about open ports, then he can plan different attack techniques through the open ports.

Quick Fix

It is always recommended to check and close all the unwanted ports to safeguard the system from malicious attacks.

Ping Sweep

A ping sweep is a network scanning technique that you can use to determine which IP address from a range of IP addresses map to live hosts. Ping Sweep is also known as **ICMP sweep**.

You can use **fping** command for ping sweep. This command is a ping-like program which uses the Internet Control Message Protocol (ICMP) echo request to determine if a host is up.

fping is different from **ping** in that you can specify any number of hosts on the command line, or specify a file containing the lists of hosts to ping. If a host does not respond within a certain time limit and/or retry limit, it will be considered unreachable.

DNS Enumeration

Domain Name Server (DNS) is like a map or an address book. In fact, it is like a distributed database which is used to translate an IP address 192.111.1.120 to a name www.example.com and vice versa.

DNS enumeration is the process of locating all the DNS servers and their corresponding records for an organization. The idea is to gather as much interesting details as possible about your target before initiating an attack.

You can use **nslookup** command available on Linux to get DNS and host-related information. In addition, you can use the following **DNSenum** script to get detailed information about a domain:

[DNSenum.pl](#)

DNSenum script can perform the following important operations:

- Get the host's addresses
- Get the nameservers
- Get the MX record
- Perform **axfr** queries on nameservers
- Get extra names and subdomains via **Google scraping**
- Brute force subdomains from file can also perform recursion on subdomain that has NS records
- Calculate C class domain network ranges and perform **whois** queries on them
- Perform **reverse lookups** on **netranges**.

Sniffing

Sniffing is the process of monitoring and capturing all the packets passing through a given network using sniffing tools. It is a form of “tapping phone wires” and get to know about the conversation. It is also called **wiretapping** applied to the computer networks.

There is so much possibility that if a set of enterprise switch ports is open, then one of their employees can sniff the whole traffic of the network. Anyone in the same physical location can plug into the network using Ethernet cable or connect wirelessly to that network and sniff the total traffic.

In other words, Sniffing allows you to see all sorts of traffic, both protected and unprotected. In the right conditions and with the right protocols in place, an attacking party may be able to gather information that can be used for further attacks or to cause other issues for the network or system owner.

What can be sniffed?

One can sniff the following sensitive information from a network –

- Email traffic
- FTP passwords
- Web traffics
- Telnet passwords
- Router configuration
- Chat sessions
- DNS traffic

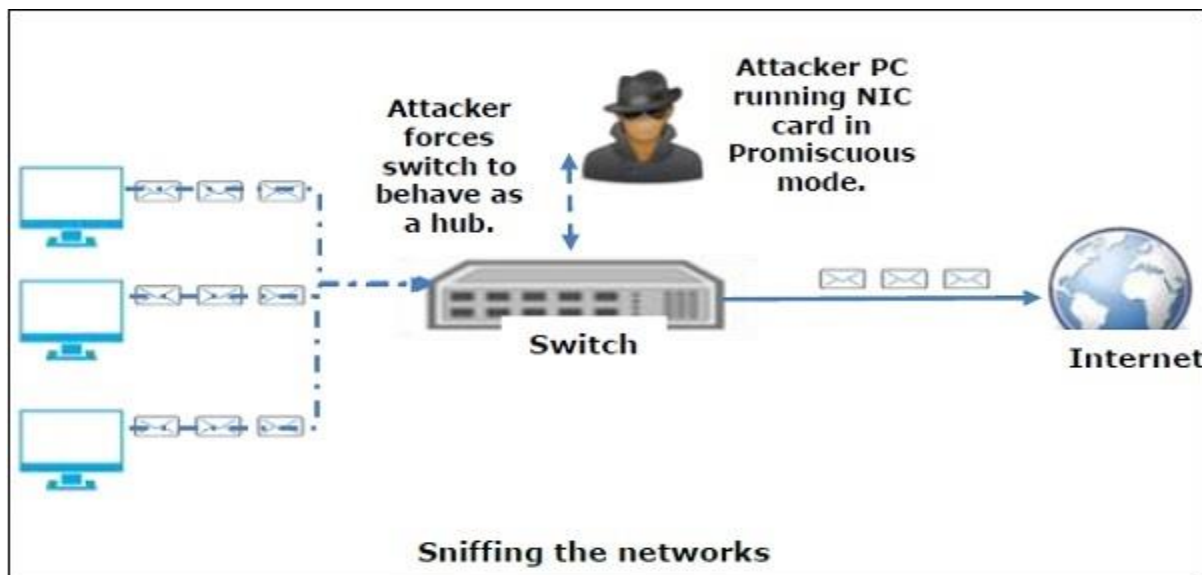
How it works

A sniffer normally turns the NIC of the system to the **promiscuous mode** so that it listens to all the data transmitted on its segment.

Promiscuous mode refers to the unique way of Ethernet hardware, in particular, network interface cards (NICs), that allows an NIC to receive all

traffic on the network, even if it is not addressed to this NIC. By default, a NIC ignores all traffic that is not addressed to it, which is done by comparing the destination address of the Ethernet packet with the hardware address (a.k.a. MAC) of the device. While this makes perfect sense for networking, non-promiscuous mode makes it difficult to use network monitoring and analysis software for diagnosing connectivity issues or traffic accounting.

A sniffer can continuously monitor all the traffic to a computer through the NIC by decoding the information encapsulated in the data packets.



Types of Sniffing

Sniffing can be either Active or Passive in nature.

Passive Sniffing

In passive sniffing, the traffic is locked but it is not altered in any way. Passive sniffing allows listening only. It works with Hub devices. On a hub device, the traffic is sent to all the ports. In a network that uses hubs to connect systems, all hosts on the network can see the traffic. Therefore, an attacker can easily capture traffic going through.

The good news is that hubs are almost obsolete nowadays. Most modern networks use switches. Hence, passive sniffing is no more effective.

Active Sniffing

In active sniffing, the traffic is not only locked and monitored, but it may also be altered in some way as determined by the attack. Active sniffing is used to sniff a switch-based network. It involves injecting **address resolution packets** (ARP) into a target network to flood on the switch **content addressable memory** (CAM) table. CAM keeps track of which host is connected to which port.

Following are the Active Sniffing Techniques:

- MAC Flooding
- DHCP Attacks
- DNS Poisoning
- Spoofing Attacks
- ARP Poisoning

Protocols which are affected

Protocols such as the tried and true TCP/IP were never designed with security in mind and therefore do not offer much resistance to potential intruders. Several rules lend themselves to easy sniffing –

- **HTTP** – It is used to send information in the clear text without any encryption and thus a real target.
- **SMTP** (Simple Mail Transfer Protocol) – SMTP is basically utilized in the transfer of emails. This protocol is efficient, but it does not include any protection against sniffing.
- **NNTP** (Network News Transfer Protocol)– It is used for all types of communications, but its main drawback is that data and even passwords are sent over the network as clear text.
- **POP** (Post Office Protocol) – POP is strictly used to receive emails from the servers. This protocol does not include protection against sniffing because it can be trapped.

- **FTP** (File Transfer Protocol) – FTP is used to send and receive files, but it does not offer any security features. All the data is sent as clear text that can be easily sniffed.
- **IMAP** (Internet Message Access Protocol) – IMAP is same as SMTP in its functions, but it is highly vulnerable to sniffing.
- **Telnet** – Telnet sends everything (usernames, passwords, keystrokes) over the network as clear text and hence, it can be easily sniffed.

Sniffers are not the dumb utilities that allow you to view only live traffic. If you really want to analyze each packet, save the capture and review it whenever time allows.

Hardware Protocol Analyzers

Before we go into further details of sniffers, it is important that we discuss about **hardware protocol analyzers**. These devices plug into the network at the hardware level and can monitor traffic without manipulating it.

- Hardware protocol analyzers are used to monitor and identify malicious network traffic generated by hacking software installed in the system.
- They capture a data packet, decode it, and analyze its content according to certain rules.
- Hardware protocol analyzers allow attackers to see individual data bytes of each packet passing through the cable.

These hardware devices are not readily available to most ethical hackers due to their enormous cost in many cases.

Lawful Interception

Lawful Interception (LI) is defined as legally sanctioned access to communications network data such as telephone calls or email messages. LI must always be in pursuance of a lawful authority for the purpose of analysis or evidence. Therefore, LI is a security process in which a network operator or service provider gives law enforcement officials

permission to access private communications of individuals or organizations.

Almost all countries have drafted and enacted legislation to regulate lawful interception procedures; standardization groups are creating LI technology specifications. Usually, LI activities are taken for the purpose of infrastructure protection and cyber security. However, operators of private network infrastructures can maintain LI capabilities within their own networks as an inherent right, unless otherwise prohibited.

LI was formerly known as **wiretapping** and has existed since the inception of electronic communications.

There are so many tools available to perform sniffing over a network, and they all have their own features to help a hacker analyze traffic and dissect the information. Sniffing tools are extremely common applications. We have listed here some of the interesting ones –

- **BetterCAP** – BetterCAP is a powerful, flexible and portable tool created to perform various types of MITM attacks against a network, manipulate HTTP, HTTPS and TCP traffic in real-time, sniff for credentials, and much more.
- **Ettercap** – Ettercap is a comprehensive suite for man-in-the-middle attacks. It features sniffing of live connections, content filtering on the fly and many other interesting tricks. It supports active and passive dissection of many protocols and includes many features for network and host analysis.
- **Wireshark** – It is one of the most widely known and used packet sniffers. It offers a tremendous number of features designed to assist in the dissection and analysis of traffic.
- **Tcpdump** – It is a well-known command-line packet analyzer. It provides the ability to intercept and observe TCP/IP and other packets during transmission over the network. Available at www.tcpdump.org.
- **WinDump** – A Windows port of the popular Linux packet sniffer tcpdump, which is a command-line tool that is perfect for displaying header information.

- **OmniPeek** – Manufactured by WildPackets, OmniPeek is a commercial product that is the evolution of the product EtherPeek.
- **Dsniff** – A suite of tools designed to perform sniffing with different protocols with the intent of intercepting and revealing passwords. Dsniff is designed for Unix and Linux platforms and does not have a full equivalent on the Windows platform.
- **EtherApe** – It is a Linux/Unix tool designed to display graphically a system's incoming and outgoing connections.
- **MSN Sniffer** – It is a sniffing utility specifically designed for sniffing traffic generated by the MSN Messenger application.
- **NetWitnessNextGen** – It includes a hardware-based sniffer, along with other features, designed to monitor and analyze all traffic on a network. This tool is used by the FBI and other law enforcement agencies.

A potential hacker can use any of these sniffing tools to analyze traffic on a network and dissect information.

Address Resolution Protocol (ARP) is a stateless protocol used for resolving IP addresses to machine MAC addresses. All network devices that need to communicate on the network broadcast ARP queries in the system to find out other machines' MAC addresses. ARP Poisoning is also known as **ARP Spoofing**.

Here is how ARP works:

- When one machine needs to communicate with another, it looks up its ARP table.
- If the MAC address is not found in the table, the **ARP_request** is broadcasted over the network.
- All machines on the network will compare this IP address to MAC address.
- If one of the machines in the network identifies this address, then it will respond to the **ARP_request** with its IP and MAC address.

- The requesting computer will store the address pair in its ARP table and communication will take place.

What is ARP Spoofing?

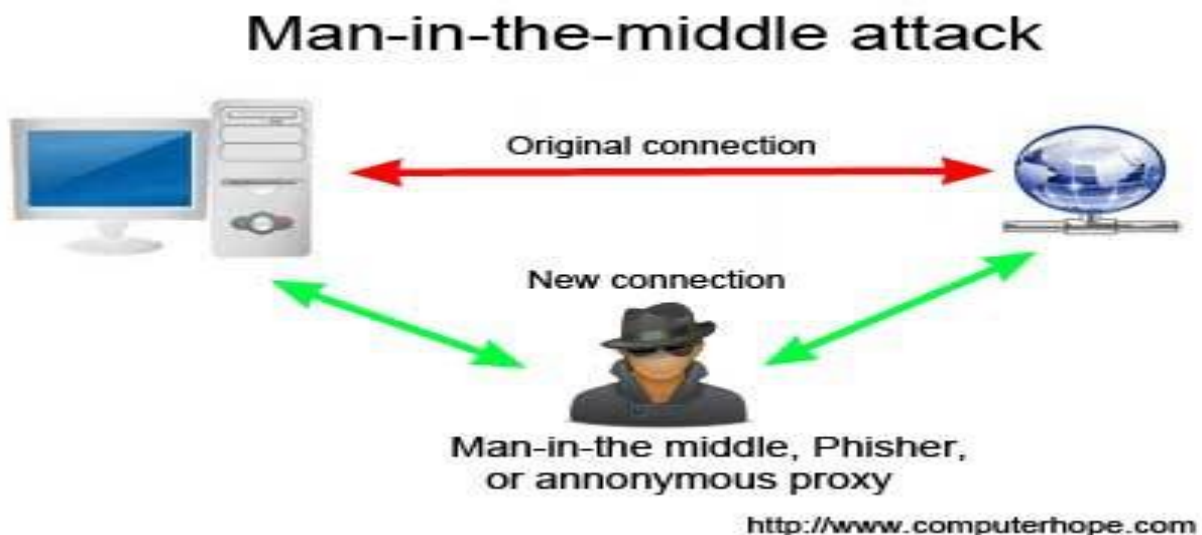
ARP packets can be forged to send data to the attacker's machine.

- ARP spoofing constructs a large number of forged ARP request and reply packets to overload the switch.
- The switch is set in **forwarding mode** and after the **ARP table** is flooded with spoofed ARP responses, the attackers can sniff all network packets.

Attackers flood a target computer ARP cache with forged entries, which is also known as **poisoning**. ARP poisoning uses Man-in-the-Middle access to poison the network.

What is MITM?

The Man-in-the-Middle attack (abbreviated MITM, MitM, MIM, MiM, MITMA) implies an active attack where the adversary impersonates the user by creating a connection between the victims and sends messages between them. In this case, the victims think that they are communicating with each other, but in reality, the malicious actor controls the communication.



A third person exists to control and monitor the traffic of communication between two parties. Some protocols such as **SSL** serve to prevent this type of attack.

ARP Poisoning – Exercise

In this exercise, we have used **BetterCAP** to perform ARP poisoning in LAN environment using VMware workstation in which we have installed **Kali** Linux and **Ettercap** tool to sniff the local traffic in LAN.

For this exercise, you would need the following tools –

- VMware workstation
- Kali Linux or Linux Operating system
- Ettercap Tool
- LAN connection

Note – This attack is possible in wired and wireless networks. You can perform this attack in local LAN.

Step 1 – Install the VMware workstation and install the Kali Linux operating system.

Step 2 – Login into the Kali Linux using username pass “root, toor”.

Step 3 – Make sure you are connected to local LAN and check the IP address by typing the command **ifconfig** in the terminal.

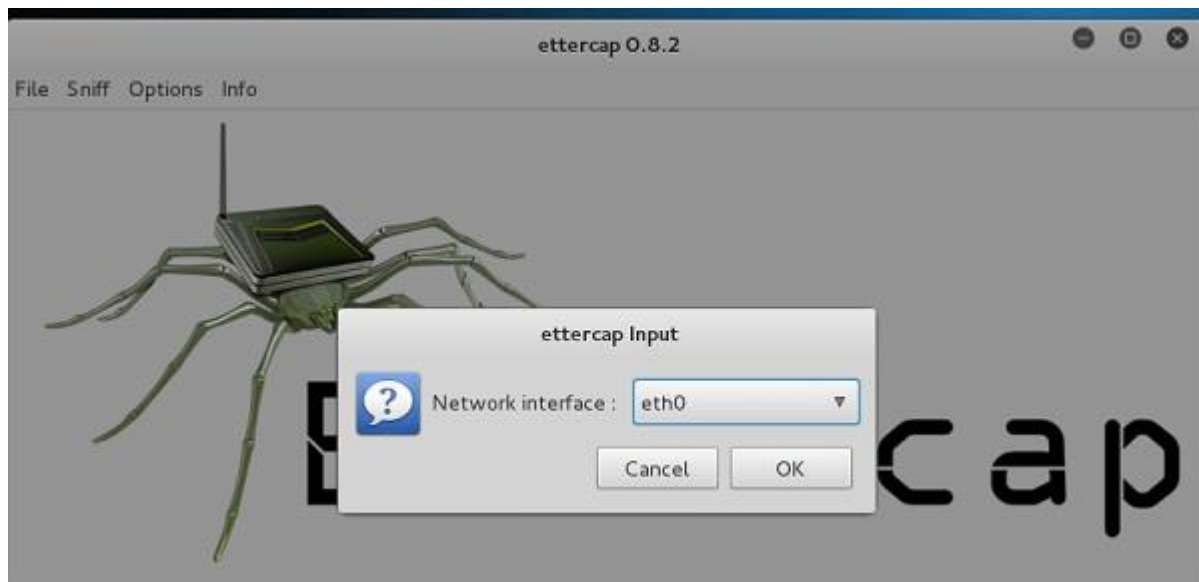
```
root@kali:~# ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:cf:f8:e7
          inet addr:192.168.121.128  Bcast:192.168.121.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fecf:f8e7/64  Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:70 errors:0 dropped:0 overruns:0 frame:0
          TX packets:54 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:4963 (4.8 KiB)  TX bytes:8868 (8.6 KiB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128  Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:16 errors:0 dropped:0 overruns:0 frame:0
          TX packets:16 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:960 (960.0 B)  TX bytes:960 (960.0 B)
```

Step 4 – Open up the terminal and type “Ettercap –G” to start the graphical version of Ettercap.

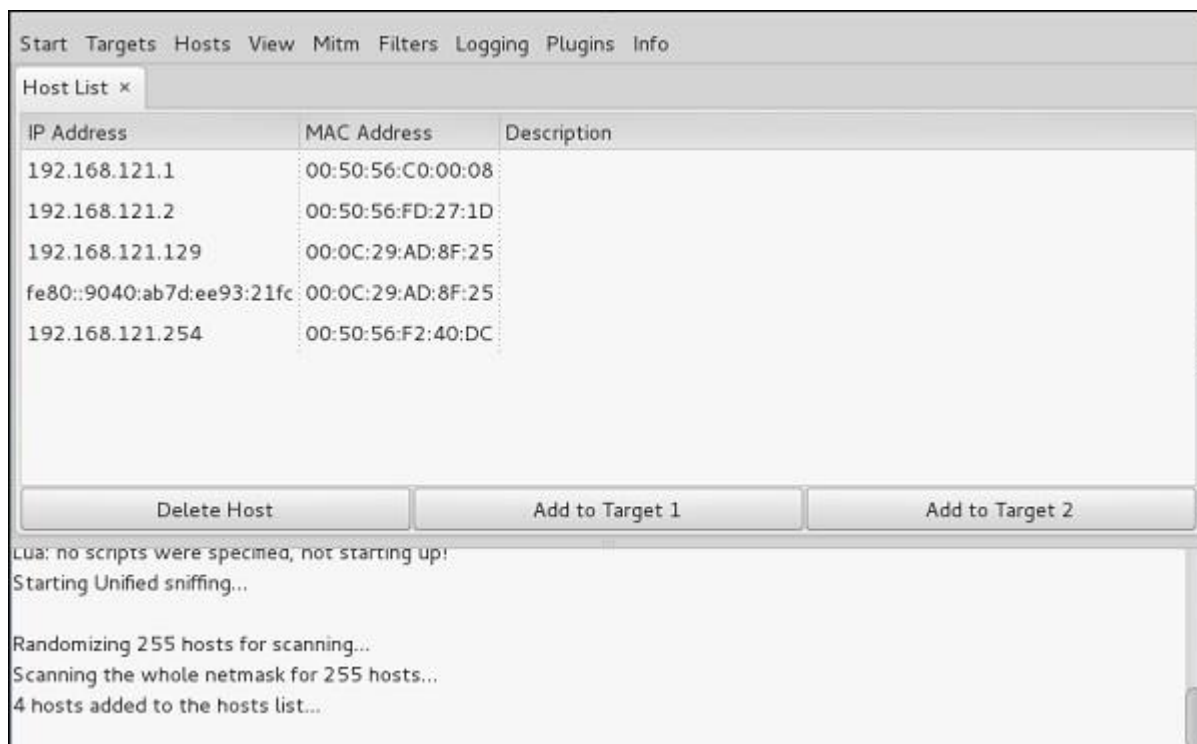


Step 5 – Now click the tab “sniff” in the menu bar and select “unified sniffing” and click OK to select the interface. We are going to use “eth0” which means Ethernet connection.



Step 6 – Now click the “hosts” tab in the menu bar and click “scan for hosts”. It will start scanning the whole network for the alive hosts.

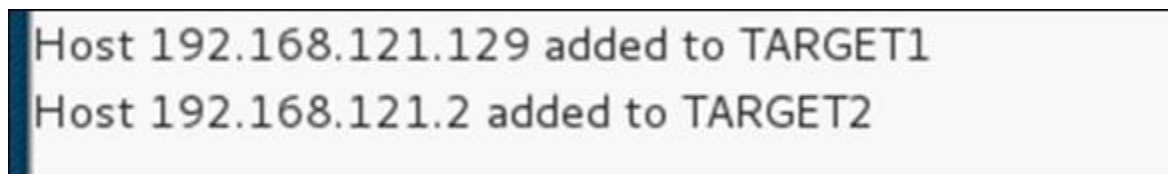
Step 7 – Next, click the “hosts” tab and select “hosts list” to see the number of hosts available in the network. This list also includes the default gateway address. We have to be careful when we select the targets.



Step 8 – Now we have to choose the targets. In MITM, our target is the host machine, and the route will be the router address to forward the traffic. In an MITM attack, the attacker intercepts the network and sniffs the packets. So, we will add the victim as “target 1” and the router address as “target 2.”

In VMware environment, the default gateway will always end with “2” because “1” is assigned to the physical machine.

Step 9 – In this scenario, our target is “192.168.121.129” and the router is “192.168.121.2”. So we will add target 1 as **victim IP** and target 2 as **router IP**.



Step 10 – Now click on “MITM” and click “ARP poisoning”. Thereafter, check the option “Sniff remote connections” and click OK.



Step 11 – Click “start” and select “start sniffing”. This will start ARP poisoning in the network which means we have enabled our network card in “promiscuous mode” and now the local traffic can be sniffed.

Note – We have allowed only HTTP sniffing with Ettercap, so don’t expect HTTPS packets to be sniffed with this process.

Step 12 – Now it’s time to see the results; if our victim logged into some websites. You can see the results in the toolbar of Ettercap.



This is how sniffing works. You must have understood how easy it is to get the HTTP credentials just by enabling ARP poisoning.

ARP Poisoning has the potential to cause huge losses in company environments. This is the place where ethical hackers are appointed to secure the networks.

Like ARP poisoning, there are other attacks such as MAC flooding, MAC spoofing, DNS poisoning, ICMP poisoning, etc. that can cause significant loss to a network.

In the next chapter, we will discuss another type of attack known as **DNS poisoning**.

DNS Poisoning is a technique that tricks a DNS server into believing that it has received authentic information when, in reality, it has not. It results in the substitution of false IP address at the DNS level where web addresses are converted into numeric IP addresses. It allows an attacker to replace IP address entries for a target site on a given DNS server with IP address of the server controls. An attacker can create fake DNS entries for the server which may contain malicious content with the same name.

For instance, a user types `www.google.com`, but the user is sent to another fraud site instead of being directed to Google's servers. As we understand, DNS poisoning is used to redirect the users to fake pages which are managed by the attackers.

DNS Poisoning – Exercise

Let's do an exercise on DNS poisoning using the same tool, **Ettercap**.

DNS Poisoning is quite similar to ARP Poisoning. To initiate DNS poisoning, you have to start with ARP poisoning, which we have already discussed in the previous chapter. We will use **DNS spoof** plugin which is already there in Ettercap.

Step 1 – Open up the terminal and type `"nanoetter.dns"`. This file contains all entries for DNS addresses which is used by Ettercap to resolve the domain name addresses. In this file, we will add a fake entry of "Facebook". If someone wants to open Facebook, he will be redirected to another website.

```
root@kali:~# locate etter.dns
/etc/ettercap/etter.dns
root@kali:~# nano /etc/ettercap/etter.dns
```

Step 2 – Now insert the entries under the words "Redirect it to `www.linux.org`". See the following example –

```
# redirect it to www.linux.org
#
www.facebook.com A 216.58.199.174
*.facebook.com A 216.58.199.174
www.facebook.com PTR 216.58.199.174
[ ]
microsoft.com A 107.170.40.56
*.microsoft.com A 107.170.40.56
www.microsoft.com PTR 107.170.40.56 # Wildcards in PTR are not allowed
```

Step 3 – Now save this file and exit by saving the file. Use “ctrl+x” to save the file.

Step 4 – After this, the whole process is same to start ARP poisoning. After starting ARP poisoning, click on “plugins” in the menu bar and select “dns_spoof” plugin.

Host List ×		Plugins ×	
Name	Version	Info	
arp_cop	1.1	Report suspicious ARP activity	
autoadd	1.2	Automatically add new victims in the target range	
chk_poison	1.1	Check if the poisoning had success	
* dns_spoof	1.2	Sends spoofed dns replies	
dos_attack	1.0	Run a d.o.s. attack against an IP address	
dummy	3.0	A plugin template (for developers)	
find_conn	1.0	Search connections on a switched LAN	
find_ettercap	2.0	Try to find ettercap activity	
find_ip	1.0	Search an unused IP address in the subnet	

Step 5 – After activating the DNS_spoof, you will see in the results that facebook.com will start spoofed to Google IP whenever someone types it in his browser.

```
Activating dns_spoof plugin...
dns_spoof: A [staticxx.facebook.com] spoofed to [216.58.199.174]
dns_spoof: A [www.facebook.com] spoofed to [216.58.199.174]
dns_spoof: A [pixel.facebook.com] spoofed to [216.58.199.174]
```

It means the user gets the Google page instead of facebook.com on their browser.

In this exercise, we saw how network traffic can be sniffed through different tools and methods. Here a company needs an ethical hacker to provide network security to stop all these attacks. Let's see what an ethical hacker can do to prevent DNS Poisoning.

Defenses against DNS Poisoning

As an ethical hacker, your work could very likely put you in a position of prevention rather than pen testing. What you know as an attacker can help you prevent the very techniques you employ from the outside.

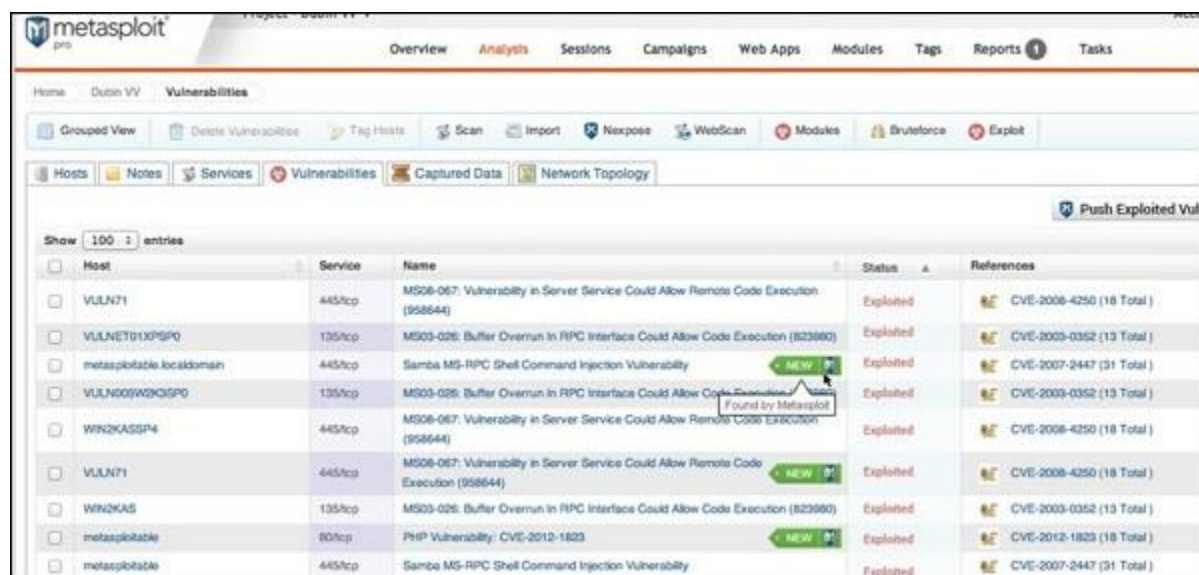
Here are defenses against the attacks we just covered from a pen tester's perspective:

- Use a hardware-switched network for the most sensitive portions of your network in an effort to isolate traffic to a single segment or collision domain.
- Implement IP DHCP Snooping on switches to prevent ARP poisoning and spoofing attacks.
- Implement policies to prevent promiscuous mode on network adapters.
- Be careful when deploying wireless access points, knowing that all traffic on the wireless network is subject to sniffing.
- Encrypt your sensitive traffic using an encrypting protocol such as SSH or IPsec.
- Port security is used by switches that have the ability to be programmed to allow only specific MAC addresses to send and receive data on each port.
- IPv6 has security benefits and options that IPv4 does not have.

- Replacing protocols such as FTP and Telnet with SSH is an effective defense against sniffing. If SSH is not a viable solution, consider protecting older legacy protocols with IPsec.
- Virtual Private Networks (VPNs) can provide an effective defense against sniffing due to their encryption aspect.
- SSL is a great defense along with IPsec.

Exploitation is a piece of programmed software or script which can allow hackers to take control over a system, exploiting its vulnerabilities. Hackers normally use vulnerability scanners like Nessus, Nexpose, OpenVAS, etc. to find these vulnerabilities.

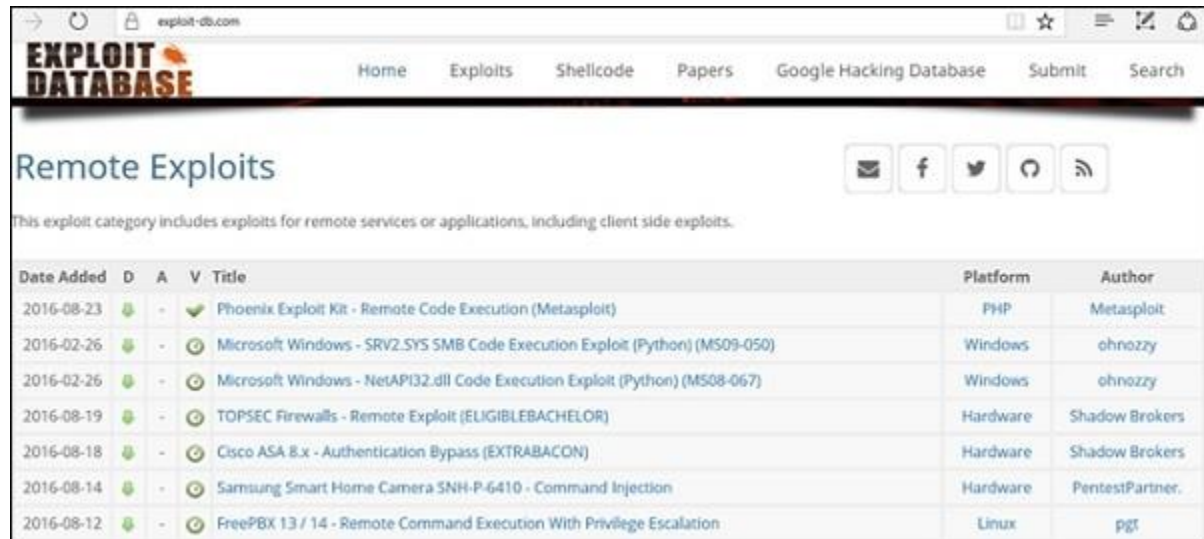
Metasploit is a powerful tool to locate vulnerabilities in a system.



Based on the vulnerabilities, we find exploits. Here, we will discuss some of the best vulnerability search engines that you can use.

Exploit Database

www.exploit-db.com is the place where you can find all the exploits related to a vulnerability.

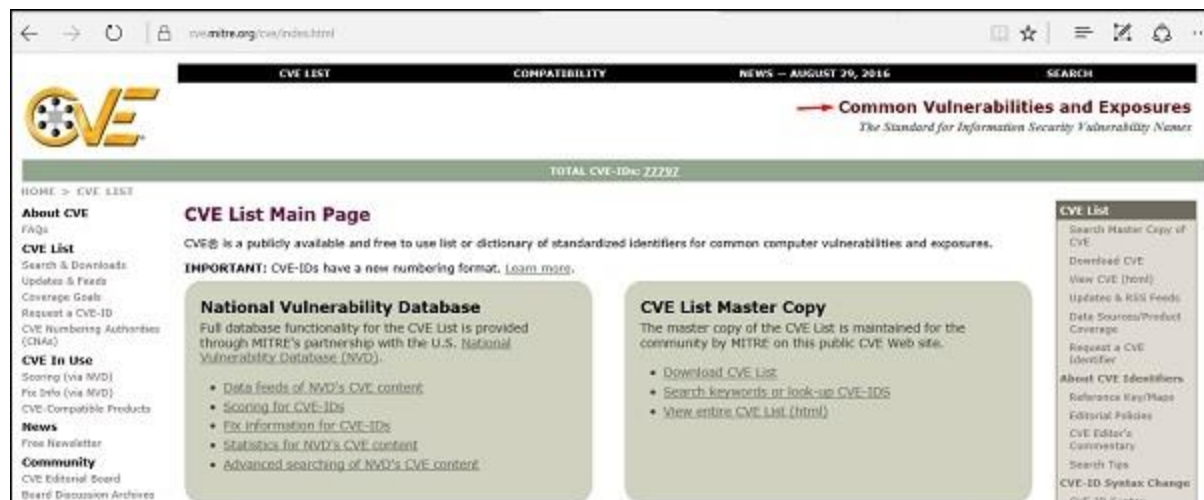


The screenshot shows the Exploit Database website with a navigation bar including Home, Exploits, Shellcode, Papers, Google Hacking Database, Submit, and Search. The main heading is "Remote Exploits" with a subtext: "This exploit category includes exploits for remote services or applications, including client side exploits." Below this is a table of exploits.

Date Added	D	A	V	Title	Platform	Author
2016-08-23	✓	-	✓	Phoenix Exploit Kit - Remote Code Execution (Metasploit)	PHP	Metasploit
2016-02-26	✓	-	✓	Microsoft Windows - SRV2.SYS SMB Code Execution Exploit (Python) (MS09-050)	Windows	ohnozzy
2016-02-26	✓	-	✓	Microsoft Windows - NetAPI32.dll Code Execution Exploit (Python) (MS08-067)	Windows	ohnozzy
2016-08-19	✓	-	✓	TOPSEC Firewalls - Remote Exploit (ELIGIBLEBACHELOR)	Hardware	Shadow Brokers
2016-08-18	✓	-	✓	Cisco ASA 8.x - Authentication Bypass (EXTRABACON)	Hardware	Shadow Brokers
2016-08-14	✓	-	✓	Samsung Smart Home Camera SNH-P-6410 - Command Injection	Hardware	PentestPartner.
2016-08-12	✓	-	✓	FreePBX 13 / 14 - Remote Command Execution With Privilege Escalation	Linux	pgf

Common Vulnerabilities and Exposures

Common Vulnerabilities and Exposures (CVE) is the standard for information security vulnerability names. CVE is a dictionary of publicly known information security vulnerabilities and exposures. It's free for public use. <https://cve.mitre.org>



The screenshot shows the CVE List Main Page on the MITRE website. The page features a navigation bar with links to CVE LIST, COMPATIBILITY, NEWS - AUGUST 29, 2016, and SEARCH. The main heading is "Common Vulnerabilities and Exposures" with the tagline "The Standard for Information Security Vulnerability Names". Below this, it states "TOTAL CVE-IDs: 77792". The page is divided into several sections: "About CVE", "CVE List" (with links for Search & Downloads, Updates & Feeds, Coverage Goals, Request a CVE-ID, CVE Numbering Authorities (CNAs), and CVE in Use), "News", "Community", "National Vulnerability Database" (with links for Data feeds, Scoring, Fix information, Statistics, and Advanced searching), "CVE List Master Copy" (with links for Download, Search keywords, and View entire CVE List), and a "CVE List" sidebar with links for Search Master Copy, Download CVE, View CVE (html), Updates & RSS Feeds, Data Sources/Product Coverage, Request a CVE (html), and About CVE Identifiers (with links for Reference Key/Map, Editorial Policies, CVE Editor's Commentary, Search Tips, and CVE-ID Syntax Change).

National Vulnerability Database

National Vulnerability Database (NVD) is the U.S. government repository of standards based vulnerability management data. This data enables automation of vulnerability management, security measurement, and compliance. You can locate this database at – <https://nvd.nist.gov>

NVD includes databases of security checklists, security-related software flaws, misconfigurations, product names, and impact metrics.



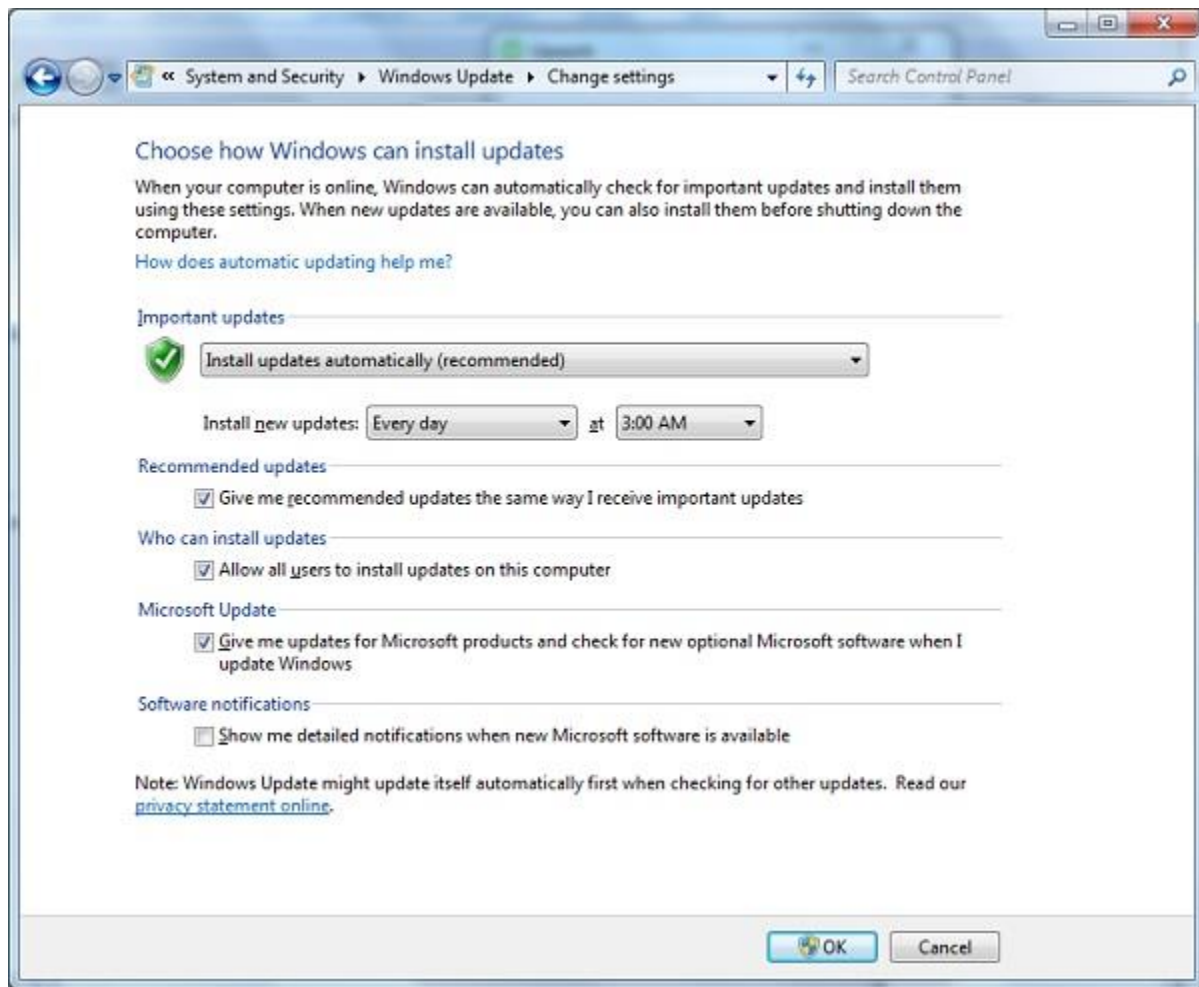
In general, you will see that there are two types of exploits –

- **Remote Exploits** – These are the type of exploits where you don't have access to a remote system or network. Hackers use remote exploits to gain access to systems that are located at remote places.
- **Local Exploits** – Local exploits are generally used by a system user having access to a local system, but who wants to overpass his rights.

Quick Fix

Vulnerabilities generally arise due to missing updates, so it is recommended that you update your system on a regular basis, for example, once a week.

In Windows environment, you can activate automatic updates by using the options available in the Control Panel → System and Security → Windows Updates.



In Linux Centos, you can use the following command to install automatic update package: `yum -y install yum-cron`

Trojans Hacking

Trojans are non-replication programs; they don't reproduce their own codes by attaching themselves to other executable codes. They operate without the permissions or knowledge of the computer users.

Trojans hide themselves in healthy processes. However we should underline that Trojans infect outside machines only with the assistance of a computer user, like clicking a file that comes attached with email from an unknown person, plugging USB without scanning, opening unsafe URLs.

Trojans have several malicious functions –

- They create backdoors to a system. Hackers can use these backdoors to access a victim system and its files. A hacker can use Trojans to edit and delete the files present on a victim system, or to observe the activities of the victim.
- Trojans can steal all your financial data like bank accounts, transaction details, PayPal related information, etc. These are called **Trojan-Banker**.
- Trojans can use the victim computer to attack other systems using Denial of Services.
- Trojans can encrypt all your files and the hacker may thereafter demand money to decrypt them. These are **Ransomware Trojans**.
- They can use your phones to send SMS to third parties. These are called **SMS Trojans**.

Trojan Information

If you have found a virus and want to investigate further regarding its function, then we will recommend that you have a look at the following virus databases, which are offered generally by antivirus vendors.

- **Kaspersky Virus database** – <https://www.kaspersky.com>
- **F-secure** – <https://www.f-secure.com>
- **Symantec – Virus Encyclopedia** – <https://www.symantec.com>

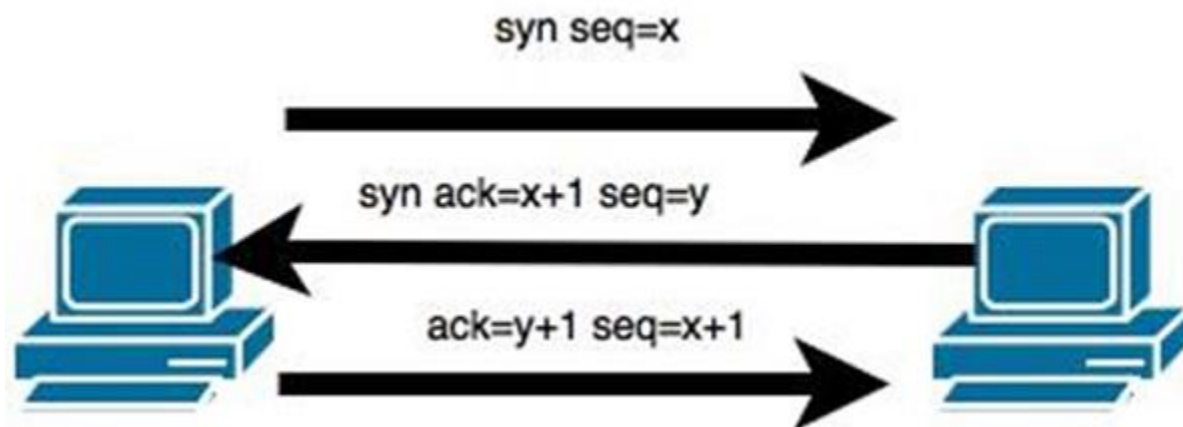
Quick Tips

- Install a good antivirus and keep it updated.
- Don't open email attachments coming from unknown sources.
- Don't accept invitation from unknown people in social media.
- Don't open URLs sent by unknown people or URLs that are in weird form.

TCP/IP Hijacking

TCP/IP Hijacking is when an authorized user gains access to a genuine network connection of another user. It is done in order to bypass the password authentication which is normally the start of a session.

In theory, a TCP/IP connection is established as shown below:



To hijack this connection, there are two possibilities –

- Find the **seq** which is a number that increases by 1, but there is no chance to predict it.
- The second possibility is to use the Man-in-the-Middle attack which, in simple words, is a type of **network sniffing**. For sniffing, we use tools like **Wireshark** or **Ethercap**.

Example

An attacker monitors the data transmission over a network and discovers the IP's of two devices that participate in a connection.

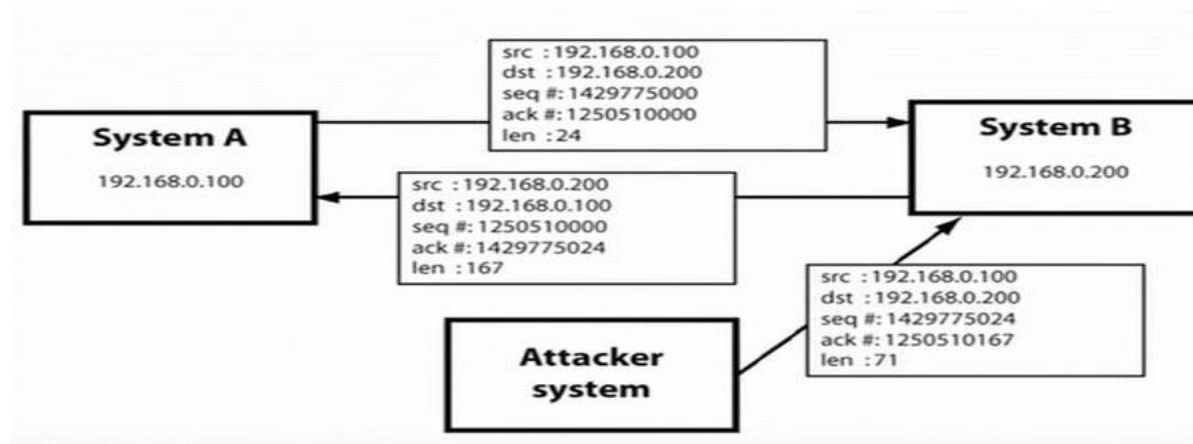
When the hacker discovers the IP of one of the users, he can put down the connection of the other user by DoS attack and then resume communication by spoofing the IP of the disconnected user.

Shijack

In practice, one of the best TCP/IP hijack tools is Shijack. It is developed using Python language and you can download it from the following link – <https://packetstormsecurity.com/sniffers/shijack.tgz>

Here is an example of a Shijack command –

```
root:/home/root/hijack# ./shijacketh0 192.168.0.100 53517 192.168.0.200
23
```



Here, we are trying to hijack a Telnet connection between the two hosts.

Email Hijacking

Email Hijacking, or email hacking, is a widespread menace nowadays. It works by using the following three techniques which are email spoofing, social engineering tools, or inserting viruses in a user computer.

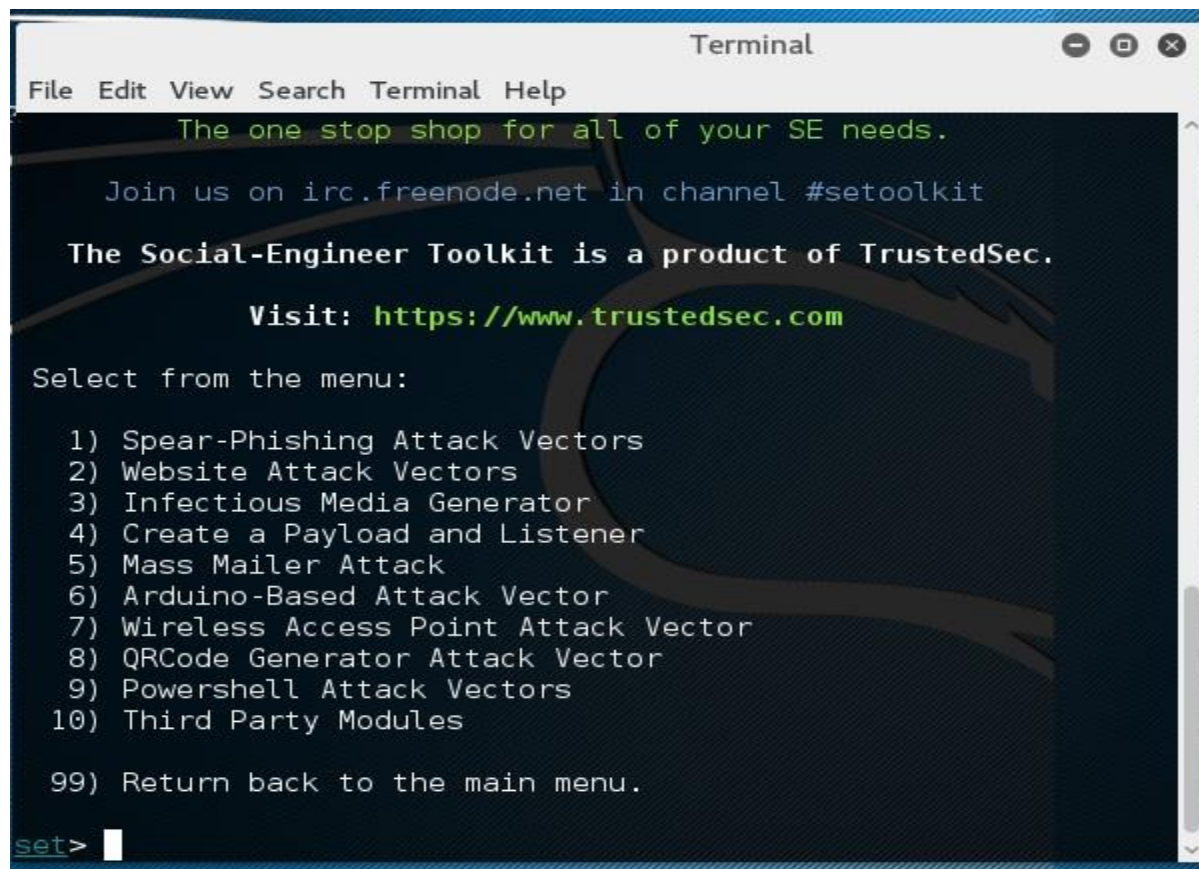
Email Spoofing

In email spoofing, the spammer sends emails from a known domain, so the receiver thinks that he knows this person and opens the mail. Such mails normally contain suspicious links, doubtful content, requests to transfer money, etc.

```
Delivered-To: al n@l.fe .com
Received: by 10.50.1.2 with SMTP id Zcsp76020igi;
    Wed, 21 May 2014 05:34:27 -0700 (PDT)
X-Received: by 10.140.18.180 with SMTP id 49mr3109738qgf.105.1400675667586;
    Wed, 21 May 2014 05:34:27 -0700 (PDT)
Return-Path: <whitson@lifelife.com>
Received: from iad1-shared-relay1.dreamhost.com (iad1-shr ad-relay1.dre ml.st.com.
    [208.113.157.50])
    by mx.google.com with ESMTP id c38si1162387age.80.2014.05.21.05.34.27
    for <example@example.com>
    Wed, 21 May 2014 05:34:27 -0700 (PDT)
Received-SPF: softfail (google.com: domain of transitioning whi : n@life.. : .com
    does not designate 208.113.157.50 as permitted sender) client-ip=208.113.157.50;
```

Social Engineering

Spammers send promotional mails to different users, offering huge discount and tricking them to fill their personal data. You have tools available in Kali that can drive you to hijack an email.

A screenshot of a terminal window titled "Terminal" with a menu bar containing "File", "Edit", "View", "Search", "Terminal", and "Help". The terminal displays the following text: "The one stop shop for all of your SE needs.", "Join us on irc.freenode.net in channel #setoolkit", "The Social-Engineer Toolkit is a product of TrustedSec.", "Visit: https://www.trustedsec.com", "Select from the menu:", a numbered list of 10 options (1) Spear-Phishing Attack Vectors, (2) Website Attack Vectors, (3) Infectious Media Generator, (4) Create a Payload and Listener, (5) Mass Mailer Attack, (6) Arduino-Based Attack Vector, (7) Wireless Access Point Attack Vector, (8) QRCode Generator Attack Vector, (9) Powershell Attack Vectors, (10) Third Party Modules, and "99) Return back to the main menu.". At the bottom, the prompt "set>" is followed by a cursor.

```
Terminal
File Edit View Search Terminal Help
The one stop shop for all of your SE needs.
Join us on irc.freenode.net in channel #setoolkit
The Social-Engineer Toolkit is a product of TrustedSec.
Visit: https://www.trustedsec.com
Select from the menu:
1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules
99) Return back to the main menu.
set> 
```

Email hacking can also be done by **phishing techniques**. See the following screenshot.



The links in the email may install malware on the user's system or redirect the user to a malicious website and trick them into divulging personal and financial information, such as passwords, account IDs or credit card details.

Phishing attacks are widely used by cybercriminals, as it is far easier to trick someone into clicking a malicious links in the email than trying to break through a computer's defenses.

Inserting Viruses in a User System

The third technique by which a hacker can hijack your email account is by infecting your system with a virus or any other kind of malware. With the help of a virus, a hacker can take all your passwords.

How to detect if your email has been hijacked?

- The recipients of spam emails include a bunch of people you know.
- You try to access your account and the password no longer works.
- You try to access the "Forgot Password" link and it does not go to the expected email.
- Your Sent Items folder contains a bunch of spams you are not aware of sending.

Quick tips

In case you think that your email got hijacked, then you need to take the following actions –

- Change the passwords immediately.
- Notify your friends not to open links that they receive from your email account.
- Contact the authorities and report that your account has been hacked.
- Install a good antivirus on your computer and update it.
- Set up double authentication password if it is supported.

Password Hacking

We have passwords for emails, databases, computer systems, servers, bank accounts, and virtually everything that we want to protect. Passwords are in general the keys to get access into a system or an account.

In general, people tend to set passwords that are easy to remember, such as their date of birth, names of family members, mobile numbers, etc. This is what makes the passwords weak and prone to easy hacking.

One should always take care to have a strong password to defend their accounts from potential hackers. A strong password has the following attributes –

- Contains at least 8 characters.
- A mix of letters, numbers, and special characters.
- A combination of small and capital letters.

Dictionary Attack

In a dictionary attack, the hacker uses a predefined list of words from a dictionary to try and guess the password.

Hydra is a popular tool that is widely used for dictionary attacks.

Hybrid Dictionary Attack

Hybrid dictionary attack uses a set of dictionary words combined with extensions. For example, we have the word "admin" and combine it with number extensions such as "admin123", "admin147", etc.

Crunch is a wordlist generator where you can specify a standard character set or a character set. **Crunch** can generate all possible combinations and permutations. This tool comes bundled with the Kali distribution of Linux.

Brute-Force Attack

In a brute-force attack, the hacker uses all possible combinations of letters, numbers, special characters, and small and capital letters to break the password. This type of attack has a high probability of success, but it requires an enormous amount of time to process all the combinations. A brute-force attack is slow and the hacker might require a system with high processing power to perform all those permutations and combinations faster.

John the Ripper or **Johnny** is one of the powerful tools to set a brute-force attack and it comes bundled with the Kali distribution of Linux.

Rainbow Tables

A rainbow table contains a set of predefined passwords that are hashed. It is a lookup table used especially in recovering plain passwords from a cipher text. During the process of password recovery, it just looks at the pre-calculated hash table to crack the password. The tables can be downloaded from <http://project-rainbowcrack.com/table.htm>

RainbowCrack 1.6.1 is the tool to use the rainbow tables. It is available again in Kali distribution.

Quick Tips

- Don't note down the passwords anywhere, just memorize them.
- Set strong passwords that are difficult to crack.

- Use a combination of alphabets, digits, symbols, and capital and small letters.
- Don't set passwords that are similar to their usernames.

Wireless Hacking

A wireless network is a set of two or more devices connected with each other via radio waves within a limited space range. The devices in a wireless network have the freedom to be in motion, but be in connection with the network and share data with other devices in the network. One of the most crucial point that they are so spread is that their installation cost is very cheap and fast than the wire networks.

Wireless networks are widely used and it is quite easy to set them up. They use IEEE 802.11 standards. A **wireless router** is the most important device in a wireless network that connects the users with the Internet.



A Wireless Router

In a wireless network, we have **Access Points** which are extensions of wireless ranges that behave as logical switches.



Although wireless networks offer great flexibility, they have their security problems. A hacker can sniff the network packets without having to be in the same building where the network is located. As wireless networks communicate through radio waves, a hacker can easily sniff the network from a nearby location.

Most attackers use network sniffing to find the SSID and hack a wireless network. When our wireless cards are converted in sniffing modes, they are called **monitor mode**.

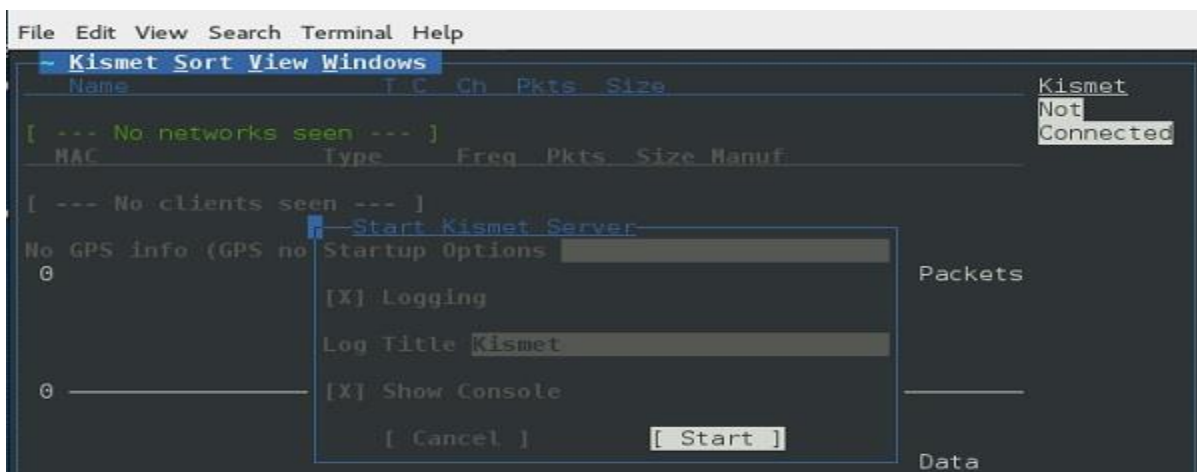
Kismet

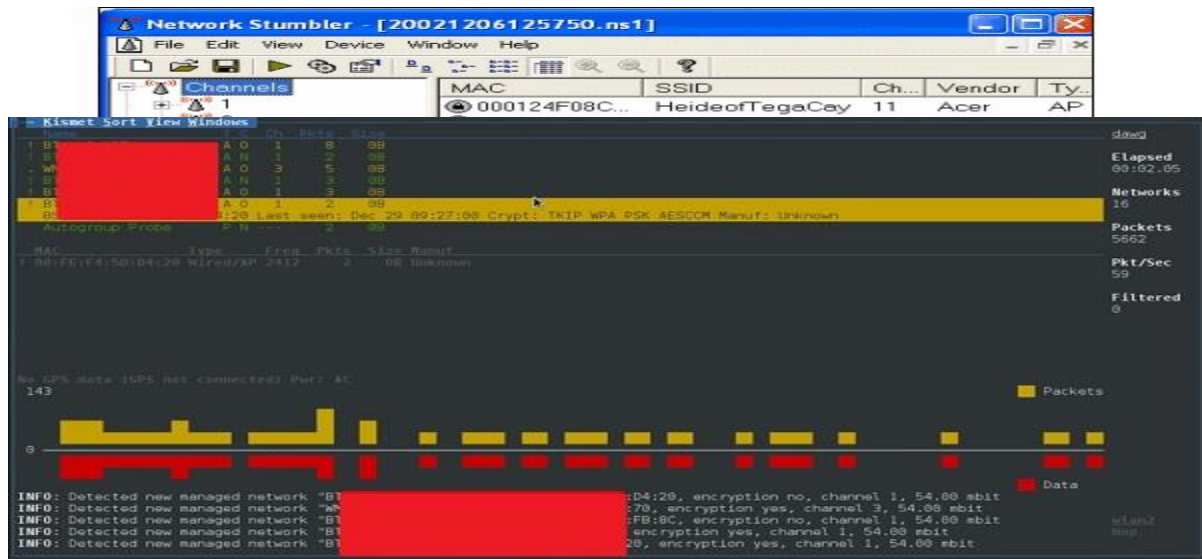
Kismet is a powerful tool for wireless sniffing that is found in Kali distribution. It can also be downloaded from its official webpage – <https://www.kismetwireless.net>

Let's see how it works. First of all, open a terminal and type **kismet**. Start the Kismet Server and click Yes, as shown in the following screenshot.



As shown here, click the Start button.



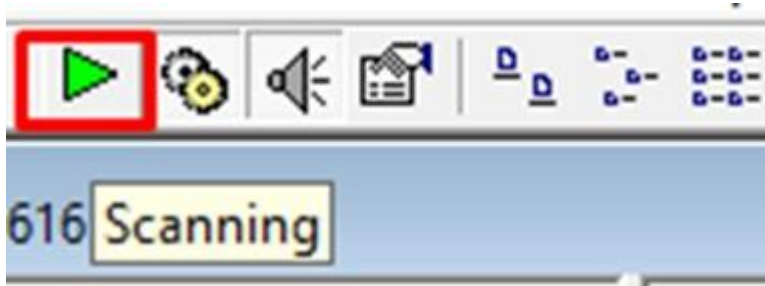


Now, Kismet will start to capture data. The following screenshot shows how it would appear –

NetStumbler

NetStumbler is another tool for wireless hacking that is primarily meant for Windows systems. It can be downloaded from <http://www.stumbler.net/>

It is quite easy to use NetStumbler on your system. You just have to click the Scanning button and wait for the result, as shown in the following screenshot.



It should display a screenshot as follows:

It is important to note that your card should support monitoring mode, otherwise you will fail to monitor.

Wired Equivalent Privacy

Wired Equivalent Privacy (WEP) is a security protocol that was invented to secure wireless networks and keep them private. It utilizes encryption at the data link layer which forbids unauthorized access to the network.

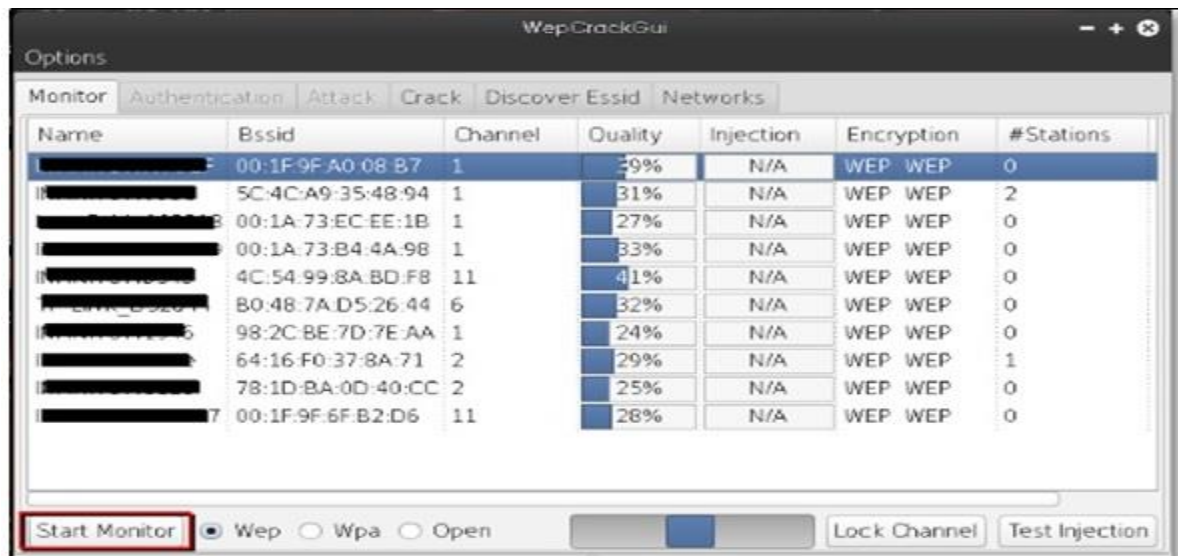
The key is used to encrypt the packets before transmission begins. An **integrity check mechanism** checks that the packets are not altered after transmission.

Note that WEP is not entirely immune to security problems. It suffers from the following issues –

- CRC32 is not sufficient to ensure complete cryptographic integrity of a packet.
- It is vulnerable to dictionary attacks.
- WEP is vulnerable to Denial of Services attacks too.

WEPcrack

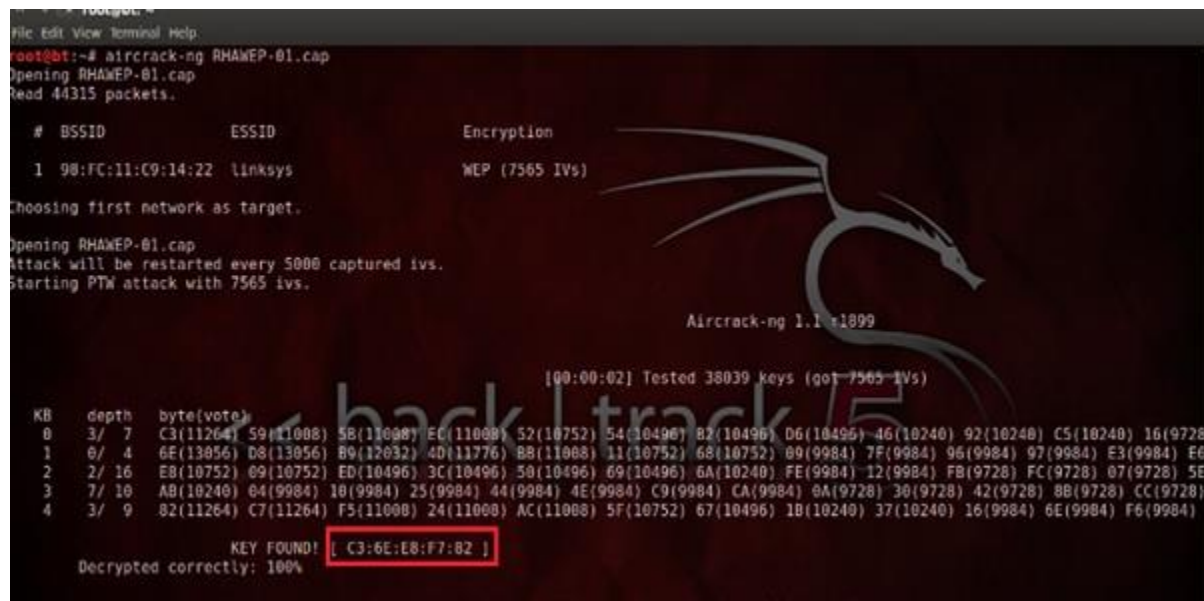
WEPcrack is a popular tool to crack WEP passwords. It can be downloaded from – <https://sourceforge.net/projects/wepcrack/>



Aircrack-ng

Aircrack-ng is another popular tool for cracking WEP passwords. It can be found in the Kali distribution of Linux.

The following screenshot shows how we have sniffed a wireless network and collected packets and created a file RHAWEP-01.cap. Then we run it with aircrack-ng to decrypt the cypher.



```

root@kali:~# aircrack-ng RHAWEP-01.cap
Opening RHAWEP-01.cap
Read 44315 packets.

# BSSID      ESSID      Encryption
1 98:FC:11:C9:14:22 linksys     WEP (7565 IVs)

Choosing first network as target.
Opening RHAWEP-01.cap
Attack will be restarted every 5000 captured ivs.
Starting PTW attack with 7565 ivs.

Aircrack-ng 1.1 r1899

[00:00:02] Tested 38039 keys (got 7565 IVs)

KB  depth  byte(vote)
0   3/ 7    C3(11264) 59(11008) 5B(11008) EC(11008) 52(10752) 54(10496) 82(10496) D6(10496) 46(10240) 92(10240) C5(10240) 16(9728)
1   6/ 4    6E(13056) D8(13056) 89(12632) 4D(11776) 8B(11008) 11(10752) 68(10752) 09(9984) 7F(9984) 96(9984) 97(9984) E3(9984) E6
2   2/ 16    E8(10752) 09(10752) ED(10496) 3C(10496) 50(10496) 69(10496) 6A(10240) FE(9984) 12(9984) FB(9728) FC(9728) 07(9728) 5E
3   7/ 10    AB(10240) 04(9984) 10(9984) 25(9984) 44(9984) 4E(9984) C9(9984) CA(9984) 0A(9728) 30(9728) 42(9728) 8B(9728) CC(9728)
4   3/ 9     02(11264) C7(11264) F5(11008) 24(11008) AC(11008) 5F(10752) 67(10496) 1B(10240) 37(10240) 16(9984) 6E(9984) F6(9984)

KEY FOUND! [ C3:6E:E8:F7:82 ]
Decrypted correctly: 100%

```

Wireless DoS Attacks

In a wireless environment, an attacker can attack a network from a distance and therefore, it is sometimes difficult to collect evidences against the attacker.

The first type of DoS is **Physical Attack**. This type of attack is very basic and it is in the base of radio interferences which can be created even from cordless phones that operate in 2.4 GHz range.

Another type is **Network DoS Attack**. As the Wireless Access Point creates a shared medium, it offers the possibility to flood the traffic of this medium toward the AP which will make its processing more slow toward the clients that attempt to connect. Such attacks can be created just by a **ping flood DoS attack**.

Pyloris is a popular DoS tool that you can download from – <https://sourceforge.net/projects/pyloris/>

Low Orbit Ion Cannon (LOIC) is another popular tool for DoS attacks.



Quick Tips

To secure a wireless network, you should keep the following points in mind:

- Change the SSID and the network password regularly.
- Change the default password of access points.
- Don't use WEP encryption.
- Turn off guest networking.
- Update the firmware of your wireless device.

Social Engineering Attacks

Let us try to understand the concept of Social Engineering attacks through some examples.

Example 1

You must have noticed old company documents being thrown into dustbins as garbage. These documents might contain sensitive information such as Names, Phone Numbers, Account Numbers, Social Security Numbers, Addresses, etc. Many companies still use carbon paper in their fax machines and once the roll is over, its carbon goes into dustbin which may have traces of sensitive data. Although it sounds improbable, but

attackers can easily retrieve information from the company dumpsters by pilfering through the garbage.

Example 2

An attacker may befriend a company personnel and establish good relationship with him over a period of time. This relationship can be established online through social networks, chatting rooms, or offline at a coffee table, in a playground, or through any other means. The attacker takes the office personnel in confidence and finally digs out the required sensitive information without giving a clue.

Example 3

A social engineer may pretend to be an employee or a valid user or an VIP by faking an identification card or simply by convincing employees of his position in the company. Such an attacker can gain physical access to restricted areas, thus providing further opportunities for attacks.

Example 4

It happens in most of the cases that an attacker might be around you and can do **shoulder surfing** while you are typing sensitive information like user ID and password, account PIN, etc.

Phishing Attack

A phishing attack is a computer-based social engineering, where an attacker crafts an email that appears legitimate. Such emails have the same look and feel as those received from the original site, but they might contain links to fake websites. If you are not smart enough, then you will type your user ID and password and will try to login which will result in failure and by that time, the attacker will have your ID and password to attack your original account.

Quick Fix

- You should enforce a good security policy in your organization and conduct required trainings to make all the employees aware of the possible Social Engineering attacks and their consequences.

- Document shredding should be a mandatory activity in your company.
- Make double sure that any links that you receive in your email is coming from authentic sources and that they point to correct websites. Otherwise you might end up as a victim of Phishing.
- Be professional and never share your ID and password with anybody else in any case.

DDOS Attacks

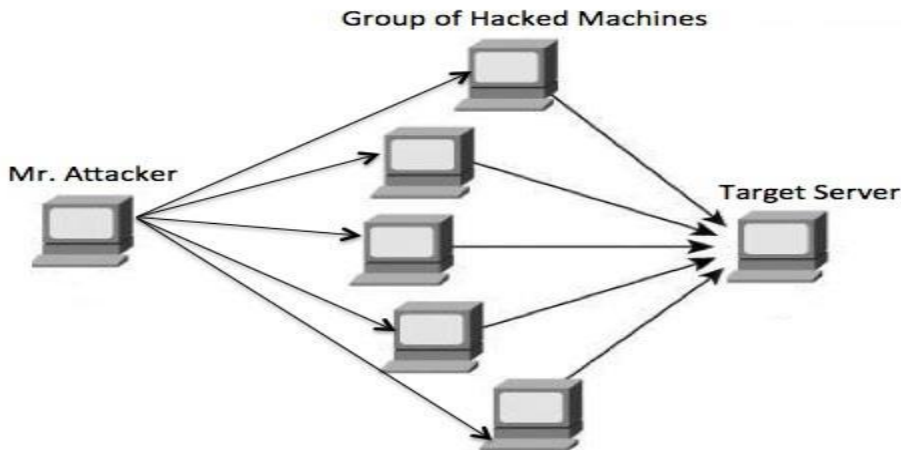
A Distributed Denial of Service (DDoS) attack is an attempt to make an online service or a website unavailable by overloading it with huge floods of traffic generated from multiple sources.

Unlike a Denial of Service (DoS) attack, in which one computer and one Internet connection is used to flood a targeted resource with packets, a DDoS attack uses many computers and many Internet connections, often distributed globally in what is referred to as a **botnet**.

A large scale volumetric DDoS attack can generate a traffic measured in tens of Gigabits (and even hundreds of Gigabits) per second. We are sure your normal network will not be able to handle such traffic.

What are Botnets?

Attackers build a network of hacked machines which are known as **botnets**, by spreading malicious piece of code through emails, websites, and social media. Once these computers are infected, they can be controlled remotely, without their owners' knowledge, and used like an army to launch an attack against any target.



A DDoS flood can be generated in multiple ways. For example –

- Botnets can be used for sending more number of connection requests than a server can handle at a time.
- Attackers can have computers send a victim resource huge amounts of random data to use up the target's bandwidth.

Due to the distributed nature of these machines, they can be used to generate distributed high traffic which may be difficult to handle. It finally results in a complete blockage of a service.

Types of DDoS Attacks

DDoS attacks can be broadly categorized into three categories –

- Volume-based Attacks
- Protocol Attacks
- Application Layer Attacks

Volume-Based Attacks

Volume-based attacks include TCP floods, UDP floods, ICMP floods, and other spoofedpacket floods. These are also called **Layer 3 & 4 Attacks**. Here, an attacker tries to saturate the bandwidth of the target site. The attack magnitude is measured in **Bits per Second** (bps).

- **UDP Flood** – A UDP flood is used to flood random ports on a remote host with numerous UDP packets, more specifically port

number 53. Specialized firewalls can be used to filter out or block malicious UDP packets.

- **ICMP Flood** – This is similar to UDP flood and used to flood a remote host with numerous ICMP Echo Requests. This type of attack can consume both outgoing and incoming bandwidth and a high volume of ping requests will result in overall system slowdown.
- **HTTP Flood** – The attacker sends HTTP GET and POST requests to a targeted web server in a large volume which cannot be handled by the server and leads to denial of additional connections from legitimate clients.
- **Amplification Attack** – The attacker makes a request that generates a large response which includes DNS requests for large TXT records and HTTP GET requests for large files like images, PDFs, or any other data files.

Protocol Attacks

Protocol attacks include SYN floods, Ping of Death, fragmented packet attacks, Smurf DDoS, etc. This type of attack consumes actual server resources and other resources like firewalls and load balancers. The attack magnitude is measured in **Packets per Second**.

- **DNS Flood** – DNS floods are used for attacking both the infrastructure and a DNS application to overwhelm a target system and consume all its available network bandwidth.
- **SYN Flood** – The attacker sends TCP connection requests faster than the targeted machine can process them, causing network saturation. Administrators can tweak TCP stacks to mitigate the effect of SYN floods. To reduce the effect of SYN floods, you can reduce the timeout until a stack frees memory allocated to a connection, or selectively dropping incoming connections using a firewall or **iptables**.
- **Ping of Death** – The attacker sends malformed or oversized packets using a simple ping command. IP allows sending 65,535 bytes packets but sending a ping packet larger than 65,535 bytes violates the Internet Protocol and could cause memory overflow on the target system and finally crash the system. To avoid Ping of

Death attacks and its variants, many sites block ICMP ping messages altogether at their firewalls.

Application Layer Attacks

Application Layer Attacks include Slowloris, Zero-day DDoS attacks, DDoS attacks that target Apache, Windows or OpenBSD vulnerabilities and more. Here the goal is to crash the web server. The attack magnitude is measured in **Requests per Second**.

- **Application Attack** – This is also called **Layer 7 Attack**, where the attacker makes excessive log-in, database-lookup, or search requests to overload the application. It is really difficult to detect Layer 7 attacks because they resemble legitimate website traffic.
- **Slowloris** – The attacker sends huge number of HTTP headers to a targeted web server, but never completes a request. The targeted server keeps each of these false connections open and eventually overflows the maximum concurrent connection pool, and leads to denial of additional connections from legitimate clients.
- **NTP Amplification** – The attacker exploits publically-accessible Network Time Protocol (NTP) servers to overwhelm the targeted server with User Datagram Protocol (UDP) traffic.
- **Zero-day DDoS Attacks** – A zero-day vulnerability is a system or application flaw previously unknown to the vendor, and has not been fixed or patched. These are new type of attacks coming into existence day by day, for example, exploiting vulnerabilities for which no patch has yet been released.

How to Fix a DDoS Attack

There are quite a few DDoS protection options which you can apply depending on the type of DDoS attack.

Your DDoS protection starts from identifying and closing all the possible OS and application level vulnerabilities in your system, closing all the possible ports, removing unnecessary access from the system and hiding your server behind a proxy or CDN system.

If you see a low magnitude of the DDoS, then you can find many firewall-based solutions which can help you in filtering out DDoS based traffic. But

if you have high volume of DDoS attack like in gigabits or even more, then you should take the help of a DDoS protection service provider that offers a more holistic, proactive and genuine approach.

You must be careful while approaching and selecting a DDoS protection service provider. There are number of service providers who want to take advantage of your situation. If you inform them that you are under DDoS attack, then they will start offering you a variety of services at unreasonably high costs.

We can suggest you a simple and working solution which starts with a search for a good DNS solution provider who is flexible enough to configure A and CNAME records for your website. Second, you will need a good CDN provider that can handle big DDoS traffic and provide you DDoS protection service as a part of their CDN package.

Assume your server IP address is AAA.BBB.CCC.DDD. Then you should do the following DNS configuration –

- Create a **A Record** in DNS zone file as shown below with a DNS identifier, for example, **ARECORDID** and keep it secret from the outside world.
- Now ask your CDN provider to link the created DNS identifier with a URL, something like **cdn.someotherid.domain.com**.
- You will use the CDN URL **cdn.someotherid.domain.com** to create two CNAME records, the first one to point to **www** and the second record to point to **@** as shown below.

You can take the help from your system administrator to understand these points and configure your DNS and CDN appropriately. Finally, you will have the following configuration at your DNS.

Type	TTL	Name	Value
A	3600	ARECORDID	AAA.BBB.CCC.DDD
CNAME	3600	www	cdn.someotherid.domain.com
CNAME	3600	@	cdn.someotherid.domain.com

Now, let the CDN provider handle all type of DDoS attacks and your system will remain safe. But here the condition is that you should not disclose your system's IP address or A record identifier to anyone; else direct attacks will start again.

Quick Fix

DDoS attacks have become more common than ever before, and unfortunately, there is no quick fix for this problem. However, if your system is under a DDoS attack, then don't panic and start looking into the matter step by step.

Cross-Site Scripting

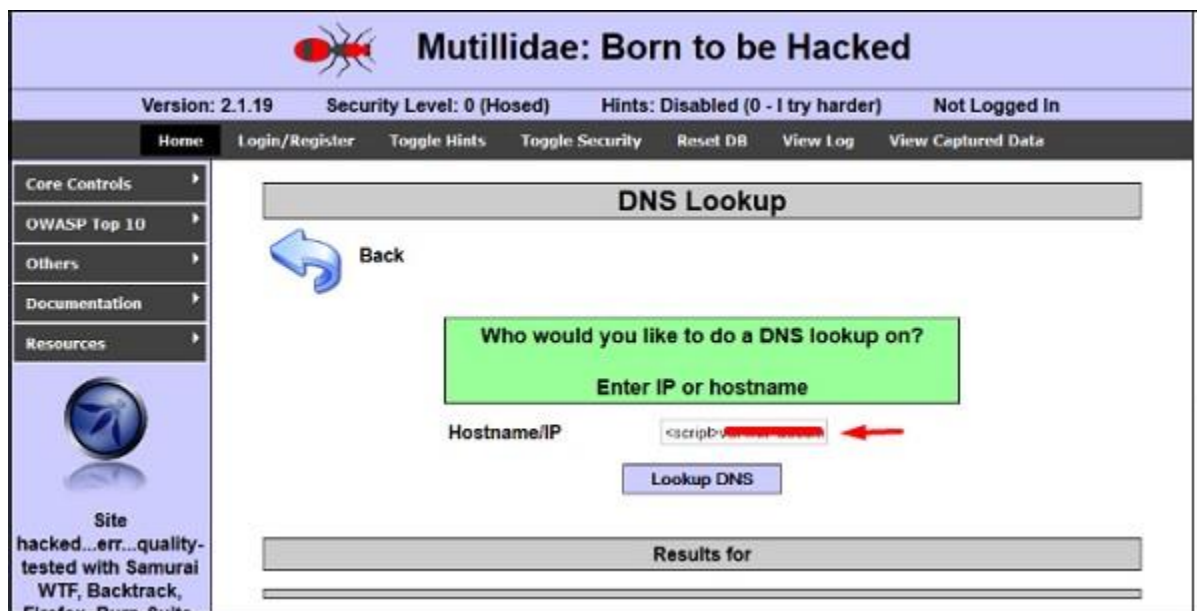
Cross-site scripting (XSS) is a code injection attack that allows an attacker to execute malicious JavaScript in another user's browser.

The attacker does not directly target his victim. Instead, he exploits a vulnerability in a website that the victim visits, in order to get the website to deliver the malicious JavaScript for him. To the victim's browser, the malicious JavaScript appears to be a legitimate part of the website, and the website has thus acted as an unintentional accomplice to the attacker. These attacks can be carried out using HTML, JavaScript, VBScript, ActiveX, Flash, but the most used XSS is malicious JavaScript.

These attacks also can gather data from account hijacking, changing of user settings, cookie theft/poisoning, or false advertising and create DoS attacks.

Example

Let's take an example to understand how it works. We have a vulnerable webpage that we got by the **metasploitable** machine. Now we will test the field that is highlighted in red arrow for XSS.



First of all, we make a simple alert script

```
<script>
alert('I am Vulnerable')
</script>
```

It will produce the following output –



Types of XSS Attacks

XSS attacks are often divided into three types –

- **Persistent XSS**, where the malicious string originates from the website's database.
- **Reflected XSS**, where the malicious string originates from the victim's request.
- **DOM-based XSS**, where the vulnerability is in the client-side code rather than the server-side code.

Generally, cross-site scripting is found by **vulnerability scanners** so that you don't have to do all the manual job by putting a JavaScript on it like

```
<script>  
alert('XSS')  
</script>
```

Burp Suite and **acunetix** are considered as the best vulnerability scanners.

Quick Tip

To prevent XSS attacks, keep the following points in mind –

- Check and validate all the form fields like hidden forms, headers, cookies, query strings.
- Implement a stringent security policy. Set character limitation in the input fields.

SQL Injection

SQL injection is a set of SQL commands that are placed in a URL string or in data structures in order to retrieve a response that we want from the databases that are connected with the web applications. This type of attacks generally takes place on webpages developed using PHP or ASP.NET.

An SQL injection attack can be done with the following intentions –

- To dump the whole database of a system,

- To modify the content of the databases, or
- To perform different queries that are not allowed by the application.

This type of attack works when the applications don't validate the inputs properly, before passing them to an SQL statement. Injections are normally placed put in address bars, search fields, or data fields.

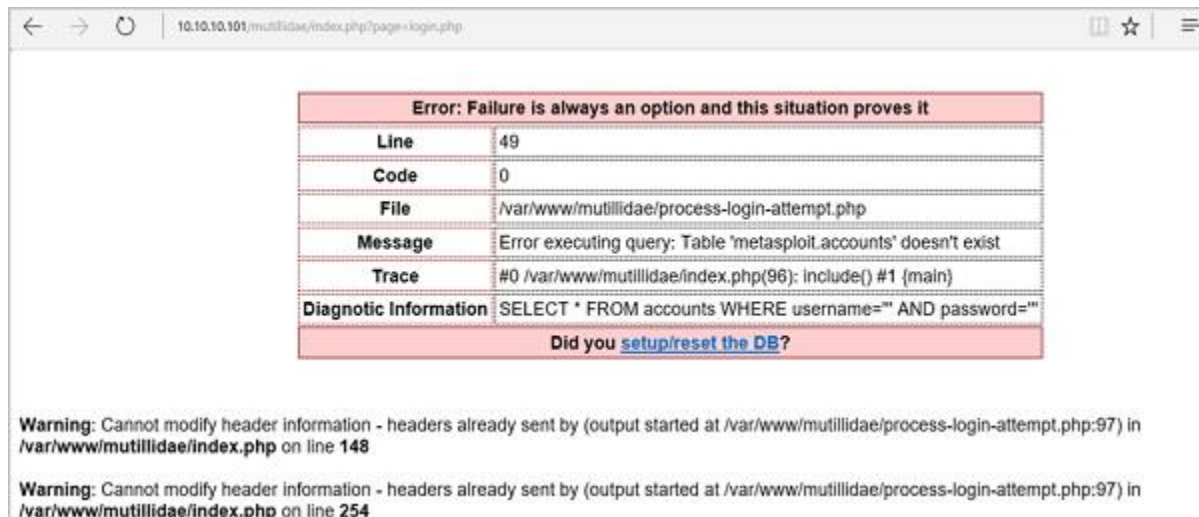
The easiest way to detect if a web application is vulnerable to an SQL injection attack is to use the " ` " character in a string and see if you get any error.

Example 1

Let's try to understand this concept using a few examples. As shown in the following screenshot, we have used a " ` " character in the Name field.



Now, click the **Login** button. It should produce the following response –



It means that the "Name" field is vulnerable to SQL injection.

Example 2

We have this URL – **`http://10.10.10.101/mutillidae/index.php?page=site-footer-xssdiscussion.php`**

And we want to test the variable "page" but observe how we have injected a "`" character in the string URL.



When we press Enter, it will produce the following result which is with errors.

SQLMAP



SQLMAP is one of the best tools available to detect SQL injections. It can be downloaded from <http://sqlmap.org/>

It comes pre-compiled in the Kali distribution. You can locate it at – Applications → Database Assessment → Sqlmap.

After opening SQLMAP, we go to the page that we have the SQL injection and then get the header request. From the header, we run the following command in SQL –

```
./sqlmap.py --headers="User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux i686; rv:25.0)
Gecko/20100101 Firefox/25.0" --cookie="security=low;
PHPSESSID=oikbs8qcic2omf5gnd09kihs7" -u '
http://localhost/dvwa/vulnerabilities/sqli_blind/?id=1&Submit=Submit#' -
level=5 risk=3 -p id --suffix="-BR" -v3
```

The SQLMAP will test all the variables and the result will show that the parameter "id" is vulnerable, as shown in the following screenshot.

```

6886 # -BR
GET parameter 'id' is vulnerable. Do you want to keep testing the others (if any)? [y/N]
sqlmap identified the following injection points with a total of 28 HTTP(s) requests:
...
Place: GET
Parameter: id
  Type: boolean-based blind
  Title: AND boolean-based blind - WHERE or HAVING clause (Forced MySQL comment)
  Payload: id=1' AND 9827=9827 #bla -BR&Submit=Submit
  Vector: AND [INFERENCE] #
...
[14:35:31] [INFO] testing MySQL
[14:35:31] [PAYLOAD] 1' AND QUARTER(NULL) IS NULL # -BR
[14:35:31] [INFO] confirming MySQL
[14:35:31] [PAYLOAD] 1' AND USER() LIKE USER() # -BR
[14:35:31] [PAYLOAD] 1' AND ISNULL(TIMESTAMPADD(MINUTE,3147,NULL)) # -BR
[14:35:32] [INFO] the back-end DBMS is MySQL
web application technology: Apache 2.2.21, PHP 5.3.8
back-end DBMS: MySQL >= 5.0.0
[14:35:32] [INFO] fetched data logged to text files under '/home/twsl/tools/sqlmap/output/local
host'

[*] shutting down at 14:35:32

```

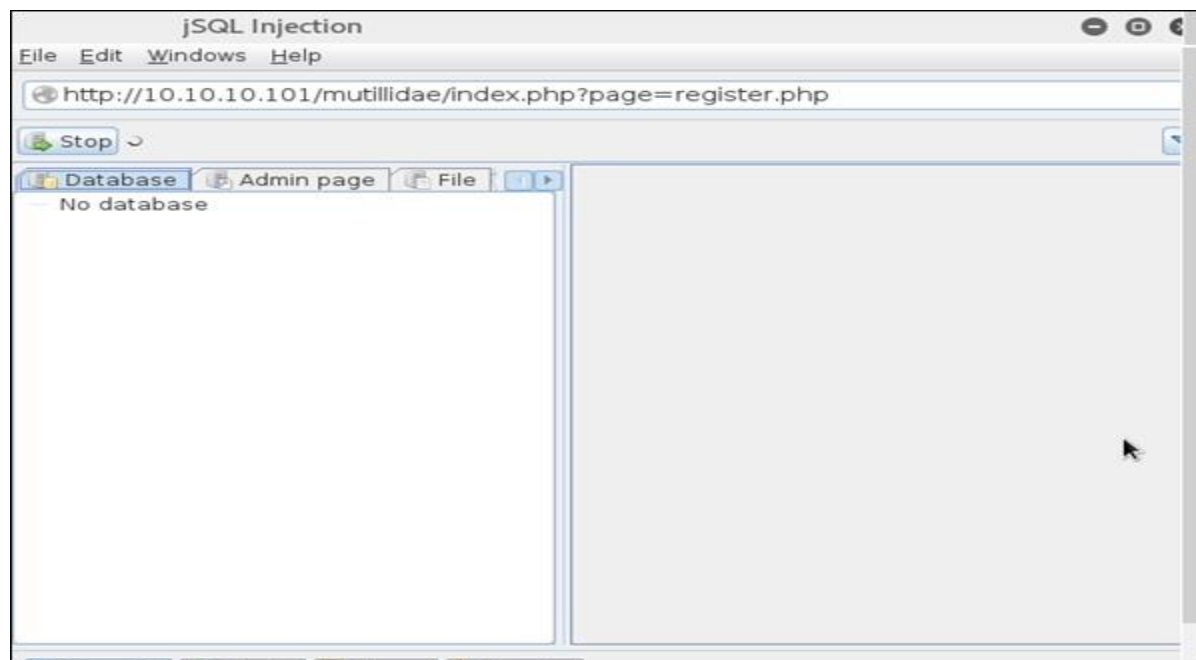
SQLNinja

SQLNinja is another SQL injection tool that is available in Kali distribution.

```
SqlNinja rel. 0.2.6-rl
Copyright (C) 2006-2011 icesurfer <r00t@northernfortress.net>
Usage: /usr/bin/sqlninja
  -m <mode> : Required. Available modes are:
    t/test - test whether the injection is working
    f/fingerprint - fingerprint user, xp_cmdshell and more
    b/bruteforce - bruteforce sa account
    e/escalation - add user to sysadmin server role
    x/resurrectxp - try to recreate xp_cmdshell
    u/upload - upload a .scr file
    s/dirshell - start a direct shell
    k/backscan - look for an open outbound port
    r/revshell - start a reverse shell
    d/dnstunnel - attempt a dns tunneled shell
    i/icmpshell - start a reverse ICMP shell
    c/sqlcmd - issue a 'blind' OS command
    m/metasploit - wrapper to Metasploit stagers
  -f <file> : configuration file (default: sqlninja.conf)
  -p <password> : sa password
  -w <wordlist> : wordlist to use in bruteforce mode (dictionary method
                  only)
```

JSQ Injection

JSQ Injection is in Java and it makes automated SQL injections.



Quick Tips

To prevent your web application from SQL injection attacks, you should keep the following points in mind –

- Unchecked user-input to database should not be allowed to pass through the application GUI.
- Every variable that passes into the application should be sanitized and validated.
- The user input which is passed into the database should be quoted.

Pen Testing

Penetration Testing is a method that many companies follow in order to minimize their security breaches. This is a controlled way of hiring a professional who will try to hack your system and show you the loopholes that you should fix.

Before doing a penetration test, it is mandatory to have an agreement that will explicitly mention the following parameters –

- what will be the time of penetration test,
- where will be the IP source of the attack, and
- what will be the penetration fields of the system.

Penetration testing is conducted by professional ethical hackers who mainly use commercial, open-source tools, automate tools and manual checks. There are no restrictions; the most important objective here is to uncover as many security flaws as possible.

Types of Penetration Testing

We have five types of penetration testing –

- **Black Box** – Here, the ethical hacker doesn't have any information regarding the infrastructure or the network of the organization that he is trying to penetrate. In black-box penetration testing, the hacker tries to find the information by his own means.

- **Grey Box** – It is a type of penetration testing where the ethical hacker has a partial knowledge of the infrastructure, like its domain name server.
- **White Box** – In white-box penetration testing, the ethical hacker is provided with all the necessary information about the infrastructure and the network of the organization that he needs to penetrate.
- **External Penetration Testing** – This type of penetration testing mainly focuses on network infrastructure or servers and their software operating under the infrastructure. In this case, the ethical hacker tries the attack using public networks through the Internet. The hacker attempts to hack the company infrastructure by attacking their webpages, webservers, public DNS servers, etc.
- **Internal Penetration Testing** – In this type of penetration testing, the ethical hacker is inside the network of the company and conducts his tests from there.

Penetration testing can also cause problems such as system malfunctioning, system crashing, or data loss. Therefore, a company should take calculated risks before going ahead with penetration testing. The risk is calculated as follows and it is a management risk.

ETHICAL HACKING TERMS

Following is a list of important terms used in the field of hacking:

Adware – Adware is software designed to force pre-chosen ads to display on your system.

Attack – An attack is an action that is done on a system to get its access and extract sensitive data.

Back door – A back door, or trap door, is a hidden entry to a computing device or software that bypasses security measures, such as logins and password protections.

Bot – A bot is a program that automates an action so that it can be done repeatedly at a much higher rate for a more sustained period than a human operator could do it. For example, sending HTTP, FTP or

Telnet at a higher rate or calling script to create objects at a higher rate.

Botnet – A botnet, also known as zombie army, is a group of computers controlled without their owners' knowledge. Botnets are used to send spam or make denial of service attacks.

Brute force attack – A brute force attack is an automated and the simplest kind of method to gain access to a system or website. It tries different combination of usernames and passwords, over and over again, until it gets in.

Buffer Overflow – Buffer Overflow is a flaw that occurs when more data is written to a block of memory, or buffer, than the buffer is allocated to hold.

Clone phishing – Clone phishing is the modification of an existing, legitimate email with a false link to trick the recipient into providing personal information.

Cracker – A cracker is one who modifies the software to access the features which are considered undesirable by the person cracking the software, especially copy protection features.

Denial of service attack (DoS) – A denial of service (DoS) attack is a malicious attempt to make a server or a network resource unavailable to users, usually by temporarily interrupting or suspending the services of a host connected to the Internet.

DDoS – Distributed denial of service attack.

Exploit Kit – An exploit kit is software system designed to run on web servers, with the purpose of identifying software vulnerabilities in client machines communicating with it and exploiting discovered vulnerabilities to upload and execute malicious code on the client.

Exploit – Exploit is a piece of software, a chunk of data, or a sequence of commands that takes advantage of a bug or vulnerability to compromise the security of a computer or network system.

Firewall – A firewall is a filter designed to keep unwanted intruders outside a computer system or network while allowing safe communication between systems and users on the inside of the firewall.

Keystroke logging – Keystroke logging is the process of tracking the keys which are pressed on a computer (and which touchscreen points are used). It is simply the map of a computer/human interface. It is used by gray and black hat hackers to record login IDs and passwords. Keyloggers are usually secreted onto a device using a Trojan delivered by a phishing email.

Logic bomb – A virus secreted into a system that triggers a malicious action when certain conditions are met. The most common version is the time bomb.

Malware – Malware is an umbrella term used to refer to a variety of forms of hostile or intrusive software, including computer viruses, worms, Trojan horses, ransomware, spyware, adware, scareware, and other malicious programs.

Master Program – A master program is the program a black hat hacker uses to remotely transmit commands to infected zombie drones, normally to carry out Denial of Service attacks or spam attacks.

Phishing – Phishing is an e-mail fraud method in which the perpetrator sends out legitimate-looking emails, in an attempt to gather personal and financial information from recipients.

Phreaker – Phreakers are considered the original computer hackers and they are those who break into the telephone network illegally, typically to make free longdistance phone calls or to tap phone lines.

Rootkit – Rootkit is a stealthy type of software, typically malicious, designed to hide the existence of certain processes or programs from normal methods of detection and enable continued privileged access to a computer.

Shrink Wrap code – A Shrink Wrap code attack is an act of exploiting holes in unpatched or poorly configured software.

Social engineering – Social engineering implies deceiving someone with the purpose of acquiring sensitive and personal information, like credit card details or user names and passwords.

Spam – A Spam is simply an unsolicited email, also known as junk email, sent to a large number of recipients without their consent.

Spoofing – Spoofing is a technique used to gain unauthorized access to computers, whereby the intruder sends messages to a computer with an IP address indicating that the message is coming from a trusted host.

Spyware – Spyware is software that aims to gather information about a person or organization without their knowledge and that may send such information to another entity without the consumer's consent, or that asserts control over a computer without the consumer's knowledge.

SQL Injection – SQL injection is an SQL code injection technique, used to attack data-driven applications, in which malicious SQL statements are inserted into an entry field for execution (e.g. to dump the database contents to the attacker).

Threat – A threat is a possible danger that can exploit an existing bug or vulnerability to compromise the security of a computer or network system.

Trojan – A Trojan, or Trojan Horse, is a malicious program disguised to look like a valid program, making it difficult to distinguish from programs that are supposed to be there designed with an intention to destroy files, alter information, steal passwords or other information.

Virus – A virus is a malicious program or a piece of code which is capable of copying itself and typically has a detrimental effect, such as corrupting the system or destroying data.

Vulnerability – A vulnerability is a weakness which allows a hacker to compromise the security of a computer or network system.

Worms – A worm is a self-replicating virus that does not alter files but resides in active memory and duplicates itself.

Cross-site Scripting – Cross-site scripting (XSS) is a type of computer security vulnerability typically found in web applications. XSS enables attackers to inject client-side script into web pages viewed by other users.

Zombie Drone – A Zombie Drone is defined as a hi-jacked computer that is being used anonymously as a soldier or 'drone' for malicious activity, for example, distributing unwanted spam e-mails.

In this chapter, we will discuss in brief some of famous tools that are widely used to prevent hacking and getting unauthorized access to a computer or network system.

NMAP

Nmap stands for Network Mapper. It is an open source tool that is used widely for network discovery and security auditing. Nmap was originally designed to scan large networks, but it can work equally well for single hosts. Network administrators also find it useful for tasks such as network inventory, managing service upgrade schedules, and monitoring host or service uptime.

Nmap uses raw IP packets to determine –
what hosts are available on the network,
what services those hosts are offering,
what operating systems they are running on,
what type of firewalls are in use, and other such characteristics.

Nmap runs on all major computer operating systems such as Windows, Mac OS X, and Linux.

Metasploit

Metasploit is one of the most powerful exploit tools. It's a product of Rapid7 and most of its resources can be found at: www.metasploit.com. It comes in two versions – **commercial** and **free edition**. Metasploit can be used with command prompt or with Web UI.

With Metasploit, you can perform the following operations –

- Conduct basic penetration tests on small networks

- Run spot checks on the exploitability of vulnerabilities

- Discover the network or import scan data

- Browse exploit modules and run individual exploits on hosts

Burp Suit

Burp Suite is a popular platform that is widely used for performing security testing of web applications. It has various tools that work in collaboration to support the entire testing process, from initial mapping and analysis of an application's attack surface, through to finding and exploiting security vulnerabilities.

Burp is easy to use and provides the administrators full control to combine advanced manual techniques with automation for efficient testing. Burp can be easily configured and it contains features to assist even the most experienced testers with their work.

Angry IP Scanner

Angry IP scanner is a lightweight, cross-platform IP address and port scanner. It can scan IP addresses in any range. It can be freely copied and used anywhere. In order to increase the scanning speed, it uses multithreaded approach, wherein a separate scanning thread is created for each scanned IP address.

Angry IP Scanner simply pings each IP address to check if it's alive, and then, it resolves its hostname, determines the MAC address, scans ports, etc. The amount of gathered data about each host can be saved to TXT, XML, CSV, or IP-Port list files. With help of plugins, Angry IP Scanner can gather any information about scanned IPs.

Cain & Abel

Cain & Abel is a password recovery tool for Microsoft Operating Systems. It helps in easy recovery of various kinds of passwords by employing any of the following methods –

sniffing the network,

cracking encrypted passwords using Dictionary, Brute-Force and Cryptanalysis attacks,

recording VoIP conversations,

decoding scrambled passwords,

recovering wireless network keys,

revealing password boxes,

uncovering cached passwords and analyzing routing protocols.

Cain & Abel is a useful tool for security consultants, professional penetration testers and everyone else who plans to use it for ethical reasons.

Ettercap

Ettercap stands for Ethernet Capture. It is a network security tool for Man-in-the-Middle attacks. It features sniffing of live connections, content filtering on the fly and many other interesting tricks. Ettercap has inbuilt features for network and host analysis. It supports active and passive dissection of many protocols.

You can run Ettercap on all the popular operating systems such as Windows, Linux, and Mac OS X.

EtherPeek

EtherPeek is a wonderful tool that simplifies network analysis in a multiprotocol heterogeneous network environment. EtherPeek is a small tool (less than 2 MB) that can be easily installed in a matter of few minutes.

EtherPeek proactively sniffs traffic packets on a network. By default, EtherPeek supports protocols such as AppleTalk, IP, IP Address Resolution Protocol (ARP), NetWare, TCP, UDP, NetBEUI, and NBT packets.

SuperScan

SuperScan is a powerful tool for network administrators to scan TCP ports and resolve hostnames. It has a user friendly interface that you can use to –

Perform ping scans and port scans using any IP range.

Scan any port range from a built-in list or any given range.

View responses from connected hosts.

Modify the port list and port descriptions using the built in editor.

Merge port lists to build new ones.

Connect to any discovered open port.

Assign a custom helper application to any port.

QualysGuard

QualysGuard is an integrated suite of tools that can be utilized to simplify security operations and lower the cost of compliance. It delivers critical security intelligence on demand and automates the full spectrum of auditing, compliance and protection for IT systems and web applications.

QualysGuard includes a set of tools that can monitor, detect, and protect your global network.

WebInspect

WebInspect is a web application security assessment tool that helps identify known and unknown vulnerabilities within the Web application layer.

It can also help check that a Web server is configured properly, and attempts common web attacks such as parameter injection, cross-site scripting, directory traversal, and more.

LC4

LC4 was formerly known as **L0phtCrack**. It is a password auditing and recovery application. It is used to test password strength and sometimes to recover lost Microsoft Windows passwords, by using dictionary, brute-force, and hybrid attacks.

LC4 recovers Windows user account passwords to streamline migration of users to another authentication system or to access accounts whose passwords are lost.

LANguard Network Security Scanner

LANguard Network Scanner monitors a network by scanning connected machines and providing information about each node. You can obtain information about each individual operating system.

It can also detect registry issues and have a report set up in HTML format. For each computer, you can list the **netbios** name table, current logged-on user, and Mac address.

Network Stumbler

Network stumbler is a WiFi scanner and monitoring tool for Windows. It allows network professionals to detect WLANs. It is widely used by networking enthusiasts and hackers because it helps you find non-broadcasting wireless networks.

Network Stumbler can be used to verify if a network is well configured, its signal strength or coverage, and detect interference between one or more wireless networks. It can also be used to non-authorized connections.

ToneLoc

ToneLoc stands for Tone Locator. It was a popular war dialling computer program written for MS-DOS in the early 90's. War dialling is a technique of using a modem to automatically scan a list of telephone numbers, usually dialling every number in a local area code.

Malicious hackers use the resulting lists in breaching computer security - for guessing user accounts, or locating modems that might provide an entry-point into computer or other electronic systems.

It can be used by security personnel to detect unauthorized devices on a company's telephone network.

As an ethical hacker, you will need to understand various hacking techniques such as:

Password guessing and cracking

Session hijacking

Session spoofing

Network traffic sniffing

Denial of Service attacks

Exploiting buffer overflow vulnerabilities

SQL injection

In this chapter, we will discuss some of the skills that you would require to become an expert in Ethical Hacking.

Basic Skills

Computer Hacking is a Science as well as an Art. Like any other expertise, you need to put a lot of effort in order to acquire knowledge and become an expert hacker. Once you are on the track, you would need more effort to keep up-to-date with latest technologies, new vulnerabilities and exploitation techniques.

An ethical hacker must be a computer systems expert and needs to have very strong programming and computer networking skills.

An ethical hacker needs to have a lot of patience, persistence, and perseverance to try again and again and wait for the required result.

Additionally, an ethical hacker should be smart enough to understand the situation and other users' mind-set in order to apply social engineering exploits. A good ethical hacker has great problem-solving skills too.

COMPUTER OR DIGITAL FORENSICS (CYBER FORENSICS)

Computer forensics is the application of investigation and analysis techniques to gather and preserve evidence from a particular computing suitable for presentation in a court of law. The goal of computer forensics is to perform a structured investigation while maintaining a documented chain of evidence to find out exactly what happened on a computing device and who was responsible for it.

Forensic investigators typically follow a standard set of procedures: After physically isolating the device in question to make sure it cannot be accidentally contaminated, investigators make a digital copy of the device's storage media. Once the original media has been copied, it is locked in a safe or other secure facility to maintain its pristine condition. All investigation is done on the digital copy.

Investigators use a variety of techniques and proprietary software forensic applications to examine the copy, searching hidden folders and unallocated disk space for copies of deleted, encrypted, or damaged files. Any evidence found on the digital copy is carefully documented in a "finding report" and verified with the original in preparation for legal proceedings that involve discovery, depositions, or actual litigation.

COMPUTER FORENSICS GUIDE

The guide is aimed at a non-technical audience and provides a high-level view of computer forensics. Although the term "computer" is used, the concepts apply to any device capable of storing digital information. Where methodologies have been mentioned they are provided as examples only, and do not constitute recommendations or advice.

Uses of computer forensics

There are few areas of crime or dispute where computer forensics cannot be applied. Law enforcement agencies have been among the earliest and heaviest users of computer forensics and consequently have often been at the forefront of developments in the field.

Computers may constitute a 'scene of a crime', for example with [hacking](#) or [denial of service](#) attacks or they may hold evidence of crimes conducted elsewhere in the form of emails, internet history, documents or other files relevant to crimes such as murder, kidnap, fraud and drug trafficking.

It isn't just the content of emails, documents and other files which may be of interest to investigators but also the [metadata](#) associated with those files as well. Records of a user's actions may also be stored in log files and within other applications on a computer, such as internet browsers. A computer forensic examination may reveal when a document first appeared on a computer, when it was last edited, when it was last saved or printed and which user carried out these actions.

More recently, commercial organizations have used computer forensics to their benefit in a variety of cases such as;

- Intellectual Property theft
- Employment disputes
- Invoice fraud, often facilitated by [phishing](#) emails
- Forgeries
- Inappropriate email and internet use in the work place
- Regulatory compliance

FORENSIC GUIDELINES

For evidence to be admissible it must be reliable and not prejudicial, meaning that at all stages of a computer forensic investigation admissibility should be at the forefront of the examiner's mind. A widely used and respected set of guidelines which can guide the investigator in this area is the [*Association of Chief Police Officers Good Practice Guide for Digital Evidence*](#), or ACPO Guide for short. Although the ACPO Guide is aimed at United Kingdom law enforcement, its main principles are applicable to all computer forensics.

THE FOUR MAIN PRINCIPLES FROM THIS ARE AS FOLLOWS:

1. No action should change data held on a computer or storage media which may be subsequently relied upon in court.

2. In circumstances where a person finds it necessary to access original data held on a computer or storage media, that person must be competent to do so and be able to give evidence explaining the relevance and the implications of their actions.
3. An audit trail or other record of all processes applied to computer-based electronic evidence should be created and preserved. An independent third-party should be able to examine those processes and achieve the same result.
4. The person in charge of the investigation has overall responsibility for ensuring that the law and these principles are adhered to.

LIVE ACQUISITION

In what situations would changes to a suspect's computer by a computer forensic examiner (and therefore contravening the first principal above) be necessary?

Traditionally, the computer forensic examiner would copy data from a device which is turned off. A [write-blocker](#) would be used to make an exact bit for [bit copy](#) of the original storage medium. An [acquisition hash](#) of the original medium would be created. The examiner would then work from this copy, leaving the original demonstrably unchanged.

However, sometimes it is not possible (or desirable) to switch a computer off. It may not be possible if doing so would for example result in considerable financial or other loss for the owner. The examiner may also wish to avoid a situation whereby turning a device off may render valuable evidence to be permanently lost. In both these circumstances the computer forensic examiner would need to carry out a 'live acquisition' which would involve running a simple application on the suspect computer in order to copy (or acquire) the data to the examiner's data repository.

By running such an application (and by attaching a device to the suspect computer such a USB drive), the examiner will make changes and/or additions to the state of the computer which were not present before their actions. However,

the evidence produced would usually still be considered admissible if the examiner was able to show why such actions were considered necessary, and that they recorded those actions and that they are to explain to a court the consequences of those actions.

STAGES OF AN EXAMINATION

The examination process has been divided into six stages, presented in order of occurrence.

1. Readiness

Forensic readiness is an important and occasionally overlooked stage in the examination process. In commercial computer forensics it can include educating clients about system preparedness; for example, forensic examinations will provide stronger evidence if a device's auditing features have been activated prior to an incident taking place

For the forensic examiner, readiness includes appropriate training, testing and verification of their software and equipment, familiarity with legislation, knowing how to deal with unexpected issues (e.g., what to do if child abuse images are found during a fraud engagement) and ensuring that their data acquisition computer and associated items are adequate for the work in hand.

2. Evaluation

The evaluation stage includes the receiving of instructions, the clarification of those instructions if unclear or ambiguous, risk analysis and the allocation of roles and resources. Risk analysis for law enforcement may include an assessment on the likelihood of physical threat on entering a suspect's property and how best to counter it. Commercial organizations also need to be aware of health and safety issues, conflict of interest issues and of possible risks – financial and to their reputation – on accepting a particular project.

3. Collection

If data acquisition (often called 'imaging') is to be carried out on-site rather than at the computer forensic examiner's office, then this stage would include identifying and securing devices which may store evidence and documenting the scene. Interviews or meetings with personnel who may hold information relevant to the examination (which could include the end users of the computer, and the manager and person responsible for providing computer services, such as an IT administrator) would usually be carried out at this stage.

The collection stage can also involve the labelling and bagging of items from the site which may be used in the investigation, to be sealed in numbered tamper-evident bags. Consideration should be given to securely and safely transporting the material to the examiner's office/ laboratory.

4. Analysis

Analysis includes the discovery and extraction of information acquired in the collection stage. The type of analysis will be dependent on the requirements of each case, and can range from the extraction of a single email to piecing together the complexities of a fraud or terrorism case. During analysis the examiner will usually provide feedback to their line manager/ client; from this dialogue the analysis may take a different path or be narrowed to specific areas. Forensic analysis must be accurate, thorough, impartial, recorded, repeatable and completed within the time-scales available and resources allocated.

There are myriad tools available for computer forensics analysis. The examiner should use any tool they feel comfortable with as long as they can justify their choice. The main requirements of a computer forensic tool is that it does what it is meant to do and the only way for examiners to be sure of this is for them to regularly test and calibrate the tools they rely on before analysis takes place. 'Dual-tool verification' is able to confirm result integrity during analysis (if with tool 'A' the examiner finds artefact 'X' at location 'Y', then tool 'B' should replicate the same results hundred times).

5. Presentation

This stage usually involves the examiner producing a structured report on their findings, addressing the points in the initial instructions, along with any subsequent instructions they may have received. The report should also cover any other information which the examiner deems relevant to the investigation. It must be written with the end reader in mind; in many cases the reader will be non-technical, and so reader-appropriate terminology should be used. The examiner may be required to participate in meetings or telephone conferences to discuss and elaborate on their report.

6. Review

As with the readiness stage, the review stage is often overlooked or disregarded. This may be due to the perceived costs of doing work that is not billable, or the need 'to get on with the next job'. However, a review stage incorporated into each examination can help save money and raise the level of quality by making future examinations more efficient and time effective. A review of an examination can be simple, quick and can begin during any of the above stages. It may include a basic analysis of what went wrong, what went well, and how the learning from this can be incorporated into future examinations. Feedback from the instructing party should also be sought. Any lessons learnt from this stage should be applied to the next examination and feed into the readiness stage.

ISSUES FACING COMPUTER FORENSICS

The issues facing computer forensics examiners can be broken down into three broad categories: technical, legal and administrative.

1. Technical Issues

- a. **Encryption**– Encrypted data can be impossible to view without the correct key or password. If the key is not available or the owner will not reveal it, examiners should consider that it may be stored elsewhere on the computer or on another computer which the suspect has had access

to. It could also reside in the volatile memory of a computer (known as [RAM](#)) which is usually lost on computer shut-down; another reason to consider using live acquisition techniques, as outlined above.

b. **Increasing storage space** – Storage media hold ever greater amounts of data, which for the examiner means that their analysis computers need to have sufficient processing power and available storage capacity to efficiently deal with searching and analysing large amounts of data.

c. **New technologies** – Computing is a continually evolving field, with new hardware, software and operating systems emerging constantly. No single computer forensic examiner can be an expert on all areas, though they may frequently be expected to analyse something which they haven't previously encountered. In order to deal with this situation, the examiner should be prepared and able to test and experiment with the behaviour of new technologies. Networking and sharing knowledge with other computer forensic examiners is very useful in this respect as it's likely someone else has already come across the same issue.

d. **Anti-forensics** – Anti-forensics is the practice of attempting to thwart computer forensic analysis. This may include encryption, the overwriting of data to make it unrecoverable, the modification of files' metadata and file obfuscation (disguising files). As with encryption, the evidence that such methods have been used may be stored elsewhere on the computer or on another computer which the suspect has had access to. In our experience, it is very rare to see anti-forensics tools used correctly and frequently enough to totally obscure either their presence or the presence of the evidence that they were used to hide.

2. **Legal Issues**

a. Legislative domains - data is often not stored on a person's computer but on remote computers which they are renting storage space on, otherwise known as the 'cloud'. The location of this data may be in a

different country and therefore access to it may be via a different legislation. Access, if possible at all, can be complicated and expensive.

b. Legal arguments - Legal issues may confuse or distract from a computer examiner's findings. An example here would be the 'Trojan Defence'. A Trojan is a piece of computer code disguised as something benign but which carries a hidden and malicious purpose. Trojans have many uses, and include [key-logging](#)), uploading and downloading of files and installation of viruses. A lawyer may be able to argue that actions on a computer were not carried out by a user but were automated by a Trojan without the user's knowledge; such a Trojan Defence has been successfully used even when no trace of a Trojan or other malicious code was found on the suspect's computer. In such cases, a competent opposing lawyer, supplied with evidence from a competent computer forensic analyst, should be able to dismiss such an argument. A good examiner will have identified and addressed possible arguments from the "opposition" while carrying out the analysis and in writing their report.

3. **Administrative Issues**

a. Accepted standards – There are a plethora of standards and guidelines in computer forensics, few of which appear to be universally accepted. The reasons for this include: standard-setting bodies being tied to particular legislations; standards being aimed either at law enforcement or commercial forensics but not at both; the authors of such standards not being accepted by their peers; or high joining fees for professional bodies dissuading practitioners from participating.

b. Fit to practice – In many jurisdictions there is no qualifying body to check the competence and integrity of computer forensics professionals. In such cases anyone may present themselves as a computer forensic expert, which may result in computer forensic examinations of questionable quality and a negative view of the profession as a whole.

10 Best Tools for Computer Forensics

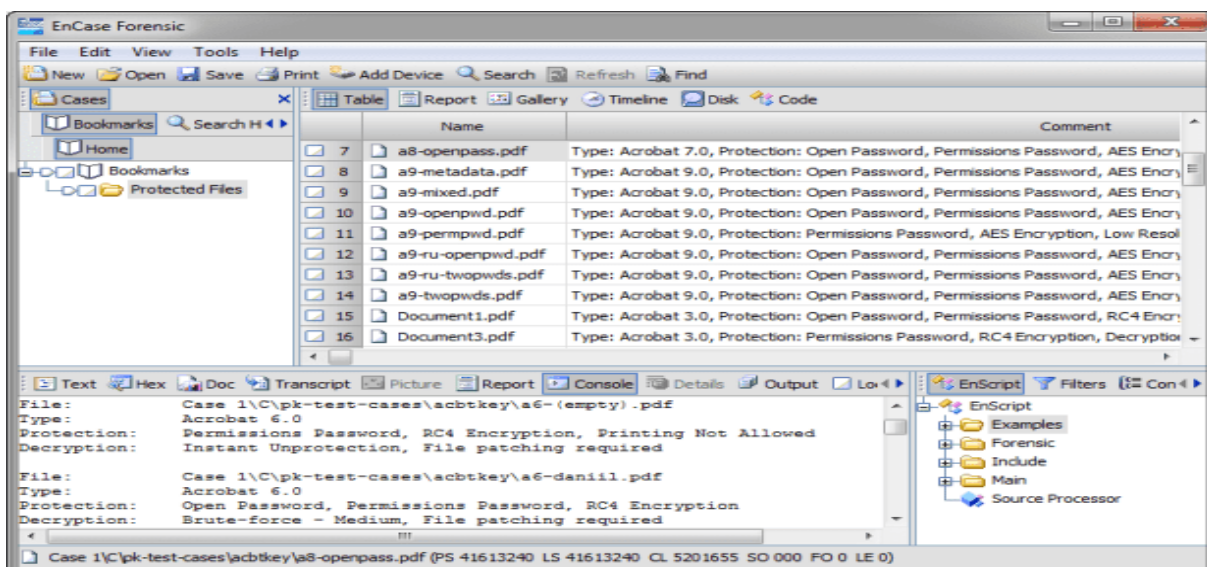
Every computer forensic gumshoe needs a set of good, solid tools to undertake a proper investigation, and the tools you use vary according to the type of investigation you're working on. **The list of tools isn't all-inclusive — and you may have your own favorites — but the ones we describe are the basic ones you should use.**

The days of hard-core computer geeks knowing every square digital inch of an operating system are years behind us. Although computer forensic professionals can now do the drudge work of scanning for evidence using nothing more than a keyboard and a hex editor, that person has access to tools that automate the work in order to use their time more effectively. In fact, modern computer forensic software can find evidence in only minutes, whereas in the "old days" the process took hours or even days! You still have to know your way around a computer, but these tools are true time-savers. **Just remember that a tool is only as good as the person who uses it.**

EnCase

EnCase, the gold standard, is used by countless organizations for almost any computer forensic investigation. The power of this must-have item for your computer forensic toolbox, and your ability to customize it for unique searches, set it apart from most competitors.

EnCase comes built-in with many forensic features, such as keyword searches, e-mail searches, and Web page carving. The numerous versions of its forensic software range from mobile device acquisitions to full-blown network forensic-analysis tools.



Two other cool features are its:

- Scripting language: You can customize searches.
- Fully automated report function: It builds reports for you quickly.

EnCase is sold by [Guidance Software](#) on its Web site. Support for EnCase is rock solid, and the technical support staff knows how to solve problems fairly quickly in addition to providing multilanguage support.

Forensic ToolKit (FTK)

[AccessData](#) has created a forensic software tool that's fairly easy to operate because of its one-touch-button interface, and it's also relatively inexpensive. The new version of FTK is even easier to use, and AccessData has started a forensic certification, ACE, based on its software.

FTK has automated, to a high degree, the hard, behind-the-scenes work of setting up searches. Press the Email button and out pop the e-mails. The FTK report generator does the hard work of putting a useful report into the automated hands of the forensic software while still allowing the investigator control over the report, if needed.

FTK is sold on the AccessData Web site at www.accessdata.com. Everything you need to order the software and training is on the site. Even the certification process is available for you to peruse.

Device Seizure

The Paraben forensic tools compete with the top two computer forensic software makers EnCase and FTK (described earlier in this chapter), but the company truly shines in the mobile forensic arena. Using Paraben's Device Seizure product, you can look at most mobile devices on the market. With more cases going mobile, Device Seizure is a must-have tool. You can use Device Seizure to access and download almost all information contained in a mobile device, such as text messages or user data, and in a way that's forensically

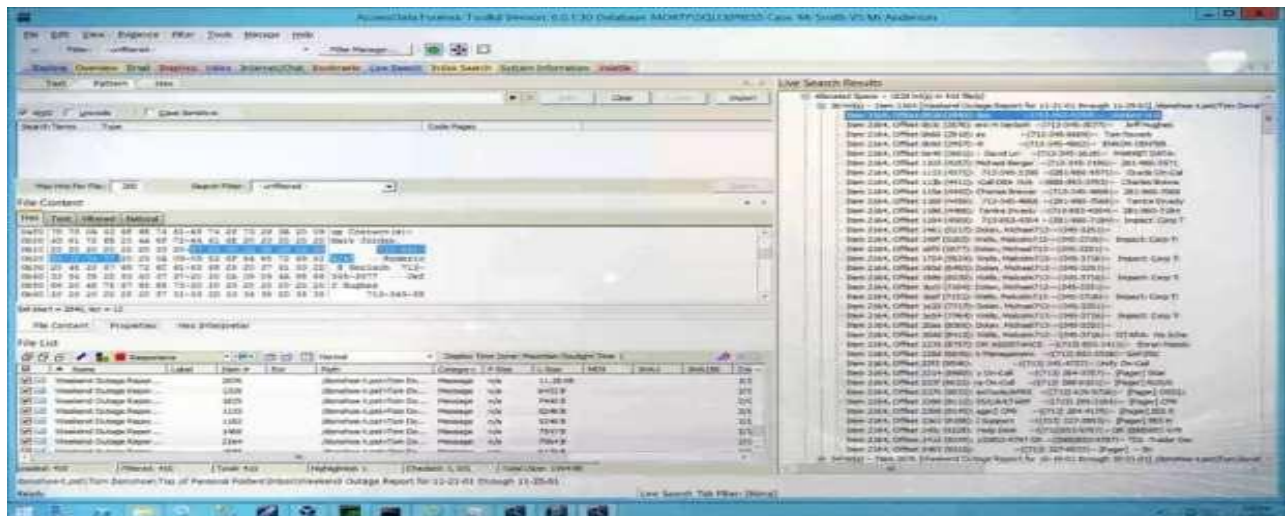
acceptable in court. Device Seizure and all the extras that can go with it are at www.paraben.com along with other useful forensic tools.

In contrast to computer forensic software designed to extract data or evidence in a timely manner and from a logical point of view, forensic hardware is primarily used to connect the physical parts of the computer to help extract the data for use with the forensic software.

The basic idea behind forensic hardware is to facilitate the forensic transfer of digital evidence from one device to another as quickly as possible.

FRED

The [Forensic Recovery of Evidence Device](#) (FRED) forensic workstation from



Digital Intelligence has an interface for all occasions — and then some. In addition to the laboratory version, FRED comes in mobile versions that facilitate the acquisition of evidence in the field for quick analysis. FRED combines just about every available interface into one convenient workstation so that you don't have to connect and disconnect a toolbox full of interfaces. Another helpful FRED feature is the collection of software packages that's loaded on it if you request it: EnCase, FTK, Paraben'sP2, and many others. Digital Intelligence, at www.digitalintelligence.com, has all the information you could ever want about the FRED systems. The company also offers training in the use of its systems and provides helpful technical support.

CRU Forensic Field Kit

When you need a small footprint and useful equipment for field use, the [CRU field kit](#) is hard to beat, figuratively and literally. Even with its small footprint, this field kit has the most popular interfaces available, and you can even customize it for your unique needs.

Using the **CRU field kit**, you can carry the most essential pieces of your forensic toolkit. The heart of this field kit consists of the write protect devices that WiebeTech manufactures in-house. The kits also contain interfaces for EIDE, SATA, and laptop hard drives.



Forensic Field Kit A6

You can find CRU field kits online [here](#), and they're also listed at some third-party Web sites.

Logicube

Logicube offers some of the fastest disk-to-disk and disk-to-image transfer equipment now on the market. As storage devices grow larger, transferring 4 gigabytes per minute can save quite a bit of time over other methods of field data acquisition.

The Logicube data capture equipment captures data from a target media and transfers it to another disk or an image while at the same time performing an

integrity check to ensure a forensic copy. The devices have various interfaces and usually come in a field kit configuration.

The Logicube Web site at www.logicube.com has information about the devices and how to order them. The company also offers other forensic products and has an in-house research-and-development team.

The computer is a reliable witness that cannot lie. Digital evidence contains an unfiltered account of a suspect's activity, recorded in his or her direct words and actions. But, some people say that using digital information as evidence is a bad idea. If it's easy to change computer data, how can it be used as reliable evidence?

To identify all the hidden details that are left after or during an incident, the computer forensics is used. The purpose of computer forensics techniques is to search, preserve and analyze information on computer systems to find potential evidence for a trial.

Computers are getting more powerful day by day, so the field of computer forensics must rapidly evolve. Previously, we had many computer forensic tools that were used to apply forensic techniques to the computer. However, we have listed few best forensic tools that are promising for today's computers:

1. SANS SIFT
2. ProDiscover Forensic
3. Volatility Framework
4. The Sleuth Kit (+Autopsy)
5. CAINE
6. Xplico
7. X-Ways Forensics

SANS SIFT:

The SANS Investigative Forensic Toolkit (SIFT) is an Ubuntu-based Live CD which includes all the tools you need to conduct an in-depth forensic or incident response investigation. The free SIFT toolkit that can match any modern incident response and forensic tool suite is also featured in SANS' Advanced Incident Response course (FOR 508). It demonstrates that advanced investigations and responding to intrusions can be accomplished using cutting-edge open-source tools that are freely available and frequently updated.

It supports analysis of Expert Witness Format, Advanced Forensic Format (AFF), and RAW (dd) evidence formats. It also includes tools such as timeline from system logs, Scalpel for data file carving, Rifiuti for examining the recycle bin, and lots more.

Key new features of SIFT include:

- Ubuntu LTS 14.04 Base.
- 64-bit base system.
- Better memory utilization.
- Auto-DFIR package update and customizations.
- Latest forensic tools and techniques.
- VMware Appliance ready to tackle forensics.
- Cross compatibility between Linux and Windows.
- Option to install stand-alone via (.iso) or use via VMware Player/Workstation.
- Online Documentation Project at <http://sift.readthedocs.org/>
- Expanded Filesystem Support.

ProDiscover Forensic:

ProDiscover Forensic is a powerful computer security tool that enables computer professionals to locate all of the data on a computer disk and at the same time protect evidence and create quality evidentiary reports for use in legal proceedings.

It can recover deleted files, examine slack space, access Windows Alternate Data Streams, and dynamically allows a preview, search, and image-capture of the Hardware Protected Area (HPA) of the disk utilizing its own pioneered the technology. It is not possible to hide data from a ProDiscover Forensic because it reads the disk at the sector level.

Key features of ProDiscover Forensic include:

- Create a Bit-Stream copy of the disk to be analyzed, including hidden HPA section (patent pending), to keep original evidence safe.
- Search files or an entire disk, including slack space, HPA section, and Windows NT/2000/XP Alternate Data Streams for complete disk forensic analysis.
- Preview all files, even if hidden or deleted, without altering data on disk, including file Metadata.
- Examine and cross reference data at the file or cluster level to ensure nothing is hidden, even in slack space.
- Utilize Perl scripts to automate investigation tasks.



Volatility Framework:

The Volatility Framework was released publicly at the BlackHat and based on years of published academic research into advanced memory analysis and forensics. Volatility framework introduced people to the power of analyzing the runtime state of a system using the data found in volatile storage (RAM). It also provided a cross-platform, modular, and extensible platform to encourage further work in this exciting area of research.

Volatility also provides a unique platform that enables cutting-edge research to be immediately transitioned into the hands of digital investigators. It has become an indispensable digital investigation tool relied upon by law enforcement, military, academia, and commercial investigators throughout the world.

The screenshot shows the EVOLVE v1.0 Web Interface for Volatility Framework (version 2.4). The interface is running on localhost. It displays a list of supported plugins on the left and a table of network connections on the right.

Supported Plugins:

Plugin Name	Action
atoms	show
callbacks	show
clipboard	show
connections	show
connscan	show
dlllist	show
getsids	show
palist	show
sockets	show
atomscan	run
auditpol	run
bigpools	run
bioskbd	run
cachedump	run
cmdline	run
cmdscan	run
consoles	run
crashinfo	run
deskscan	run
devicetree	run
clidump	run
driverirp	run
drivermodule	run
driverscan	run
dumpfiles	run
dumpregistry	run
envvars	run
eventhooks	run

connections

id	rowparent	Offset(V)	LocalAddress	RemoteAddress	PID
1	0	2296735520	10.120.245.104:3283	208.71.123.131:80	1880
2	0	2296960936	127.0.0.1:1438	127.0.0.1:1439	3164
3	0	2300017320	127.0.0.1:1439	127.0.0.1:1438	3164
4	0	2299052040	10.120.245.104:3225	74.125.65.104:80	1880
5	0	2298614264	10.120.245.104:3226	74.125.65.104:80	1880
6	0	2304801680	10.120.245.104:3248	92.61.248.130:80	1880
7	0	2299041272	10.120.245.104:3249	92.61.248.130:80	1880
8	0	2299070872	10.120.245.104:3286	96.17.164.176:80	1880
9	0	2296724448	10.120.245.104:3254	92.61.248.130:80	1880
10	0	2311060496	10.120.245.104:3243	66.177.112.72:38685	3164
11	0	2300586072	10.120.245.104:4445	10.120.245.103:1188	2728
12	0	2296750088	10.120.245.104:4445	10.120.245.103:1189	2728
13	0	2299236888	10.120.245.104:4445	10.120.245.103:1190	2728
14	0	2296686208	10.120.245.104:4445	10.120.245.103:1191	2728
15	0	2300331520	127.0.0.1:1421	127.0.0.1:1422	3164
16	0	2304744320	127.0.0.1:1422	127.0.0.1:1421	3164
17	0	2304757768	10.120.245.104:3087	75.91.87.18:5009	3164
18	0	2305802248	10.120.245.104:3263	80.67.6.35:80	1880
19	0	2299807584	10.120.245.104:3250	213.174.140.64:80	1880
20	0	2299411792	127.0.0.1:1839	127.0.0.1:1838	3164
21	0	2304738432	127.0.0.1:1838	127.0.0.1:1839	3164
22	0	2300256264	10.120.245.104:3265	74.125.157.101:80	1880
23	0	2296674408	10.120.245.104:3264	80.67.6.35:80	1880
24	0	2299807584	10.120.245.104:3251	213.174.140.64:80	1880

The Sleuth Kit is a collection of command line tools that allows us to analyze disk images and recover files from them. It is used behind the scenes in Autopsy and many other open source and commercial forensics tools.

The core functionality of The Sleuth Kit (TSK) allows you to analyze volume and file system data. The plug-in framework allows you to incorporate additional modules to analyze file contents and build automated systems.

An Autopsy is easy to use, a GUI-based program that allows us to analyze hard drives and smartphones efficiently. It has a plug-in architecture that helps us to find add-on modules or develop custom modules in Java or Python. Below is the list of Autopsy features:

- **Multi-User Cases:** Collaborate with fellow examiners on larger cases.
- **Timeline Analysis:** Displays system events in a graphical interface to help identify activity.
- **Keyword Search:** Text extraction and index searched modules enable you to find files that mention specific terms and find regular expression patterns.
- **Web Artifacts:** Extracts web activity from common browsers to help identify user activity.
- **Registry Analysis:** Uses RegRipper to identify recently accessed documents and USB devices.
- **LNK File Analysis:** Identifies shortcuts and accessed documents
- **Email Analysis:** Parses MBOX format messages, such as Thunderbird.
- **EXIF:** Extracts geolocation and camera information from JPEG files.
- **File Type Sorting:** Group files by their type to find all images or documents.
- **Media Playback:** View videos and images in the application and not require an external viewer.
- **Thumbnail Viewer:** Displays thumbnail of images to help quick view pictures.

CAINE

CAINE (Computer Aided Investigative Environment) is a Linux Live CD that contains a wealth of digital forensic tools. The latest version of Caine is based on the Ubuntu Linux LTS, MATE, and LightDM. Compared to its original version, the current version has been modified to meet the standard forensic reliability and safety standards.

Caine includes:

- **Caine Interface** – a user-friendly interface that brings together some well-known forensic tools, many of which are open source.
- Updated and optimized environment to conduct a forensic analysis.
- Semi-automatic report generator.

Features include a user-friendly GUI, semi-automated report creation and tools for Mobile Forensics, Network Forensics, Data Recovery and more.



ETHICAL HACKING BOOT CAMP — 93% EXAM PASS RATE

Xplico

Xplico is a network forensics analysis tool, which is software that reconstructs the contents of acquisitions performed with a packet sniffer (e.g. Wireshark, tcpdump, Netsniff-ng). Xplico is able to extract and reconstruct all the Web pages and contents (images, files, cookies, and so on).

Features of Xplico include:

- Protocols supported: HTTP, SIP, IMAP, POP, SMTP, TCP, UDP, IPv4, IPv6.

- Port Independent Protocol Identification (PIPI) for each application protocol;
- Multithreading;
- Output data and information in SQLite database or Mysql database and/or files;
- At each data reassembled by Xplico is associated an XML file that uniquely identifies the flows and the pcap containing the data reassembled;
- No size limit on data entry or the number of files entrance (the only limit is HD size);

Xplico is installed by default in the major distributions of digital forensics and penetration testing:

- Kali Linux
- BackTrack
- DEFT
- Security Onion
- Matriux
- BackBox
- CERT Linux Forensics Tools Repository

X-Ways Forensics

X-Ways Forensics is an advanced work environment for computer forensic examiners. X-Ways Forensics is efficient to use, not a resource-hungry, often runs faster, finds deleted files and offers many features that the others lack. X-Ways Forensics is fully portable, runs off a USB stick on any given Windows system without installation.

Key features of X-ray forensic include:

- Disk cloning and imaging
- Ability to read partitioning and file system structures inside raw (.dd) image files, ISO, VHD and VMDK images
- Complete access to disks, RAIDs, and images more than 2 TB in size
- Automatic identification of lost/deleted partitions
- Viewing and editing binary data structures using templates

- Recursive view of all existing and deleted files in all subdirectories

Computer Forensic Laboratories

Every good computer forensic scientist or investigator needs a place to do their work. In the ideal location to conduct an investigation, you have absolute control of security, tools, and even the physical environment.

Ideally, we're describing your computer forensic laboratory! As in any field of science, computer forensics requires its own set of laboratory tools to get the job done.

Computer forensic data server

Any computer forensic investigative unit of any size rapidly runs into the problem of where to store cases that are in progress or that need to be archived for possible later use. A centralized data storage solution is the best and most secure solution.

A forensic data server allows you to keep forensic images in a centralized, secure, and organized manner that lets you focus more on analyzing cases than on looking for them. A server needs to have large data capacity, the ability to authenticate users for security purposes, with the capacity to perform backups of all data in case the storage devices fail.

You can find commercial-grade servers at any of the larger computer vendors, such as Dell and HP, and at forensic companies, such as Digital Intelligence.

Forensic write blockers

One basic piece of equipment that a computer forensic laboratory needs is the simple but effective write blocker. Although most software tools have built-in software write blockers, you also need an assortment of physical write blockers to cover as many situations or devices as possible.

A write blocker is used to keep an operating system from making any changes to the original or suspect media to keep from erasing or damaging potential evidence.

Software write blockers work at the operating system level and are specific to the operating system. In other words, a software write blocker works on only the operating system in which it is installed.

A physical write blocker works at the hardware level and can work with any operating system because, at the physical level, the write blocker is intercepting (or, in many cases, blocking) electrical signals to the storage device and has no concern about which operating system is in place.

The technology used by computers to read and write to storage devices is well understood and fairly straightforward — you can find dozens of manufacturers of write-protect devices.

For reliability and support, stick with these name brands in the industry:

- Digital Intelligence: The UltraKit write-block product (see www.digitalintelligence.com) follows the everything-but-the-kitchen-sink model. All standard storage device formats, such as IDE, SCSI, SATA, and USB, are supported. In addition, the cables and power supplies are furnished, to make this kit one of the most complete in the industry.
- Paraben: Paraben has taken the idea of a Faraday box and added silverlined gloves to allow an investigator to work on a wireless device located inside the box.
- The Wireless Stronghold Box (see www.paraben.com) is a must-see for any computer forensic laboratory working with wireless devices. This box, a Faraday cage, isolates any enclosed wireless device, thus making it a wireless write blocker. For added protection, all connections leading into the box are filtered.
- Wiebetech : These write-protect devices run the spectrum from field kits to RAID systems. Wiebetech products (see www.wiebetech.com) are also sold by the major forensic software makers, which adds to their credibility.

MEDIA WIPING EQUIPMENT

Whether you complete one case per year or one case per day, you need to wipe the media you work with before you even start your case, to ensure that no cross contamination between your cases occurs. Forensic data wipers ensure that no data from a previous case is still present on the media. Most data wipers don't erase existing data per se, but instead overwrite the data with either random binary strings or a repeating pattern of bits.

You need, in addition to this capability, a report when the device is finished to prove that you wiped the drive beforehand. In a lab environment, you usually should have a dedicated device just for wiping your media so that you don't use up valuable forensic tool resources spent wiping drives rather than analyzing evidence.

All the major computer forensic software and hardware manufacturers carry data wiping equipment. Chances are good that, wherever you bought your computer forensic software, you can also purchase a dedicated data wiping unit. Just be wary of third-party data wiping tools that don't have a way to verify the data wipe and don't have a data wipe report function.

Recording equipment

Human perceptions being what they are, having an unbiased way to record events and objects is essential to computer forensic investigators. The choice of which device or devices you ultimately choose is based on your needs, but you must use some form of unbiased documentation method. Using video or audio equipment to record important aspects of a case is a useful way to permanently record an unbiased view of your case. Using a video camera, you can repeatedly visit a crime scene to look for that single clue you missed.

You can document your methods directly by recording your work or even record the output of a computer screen in a pinch. Recording your thoughts in a simple manner is often best accomplished by using a simple digital recorder that essentially acts as your personal note taker! You can find digital video cameras and audio recorders in any good retail electronics store, such as Best Buy or Radio Shack, and at Internet retailers. The basic models now available are more than enough to document all your case needs, as long as you carry extra batteries and data storage capacity.

Steganography

Steganography is a means of obscuring data where secret messages are hidden inside computer files such as images, sound files, videos and even executable files so that, no one except the sender and the receiver will suspect the existence of stealth information in it. Steganography may also involve the usage of [cryptography](#) where the message is first encrypted before it is concealed in another file. Generally, the messages appear to be something else such as an image, sound or video so that the transfer of secret data remains unsuspected.

The main advantage of steganography over other methods such as cryptography is that, it will not arouse suspicion even if the files fall in the hands of a third party. Unlike cryptographic messages, steganographic messages will no way attract the attention of a third party by themselves. Thus steganography has an upper hand over cryptography as it involves both encryption and obscurity.

What are the Applications of Steganography?

Steganography is mainly used to obscure confidential information/data during storage or transmission. For example, one can hide a secret message in an audio file and send this to another party via email instead of sending the message in the textual format. The receiver on the other end will decrypt the hidden message using the private decryption key. In a worst case scenario, even if a third party does manage to gain access to the email, all he can find is the audio file and not the hidden data inside it. Other usage of steganography include digital watermarking of images for reasons such as copyright protection.

Even though steganography has many useful applications, some may use this technique for illegitimate purposes such as hiding a pornographic content in other large files. Rumors about terrorists using steganography for hiding and communicating their secret information and instructions are also reported. An article claiming that, al-Queda had used steganography to encode messages in images and transported them via e-mails, was reported by New York Times, in October 2019.

How do Steganography Tools Work?

Stegnography tools implement intelligent algorithms to carefully embed the encrypted text messages or data inside other larger files such as an image, audio, video or an executable file. Some tools will embed the encrypted data at the end of another file so that there will be enough room for storing larger data.

There are many steganography tools available online but only a few are able to work flawlessly. I did not find any tool that worked perfectly on both small and large data. However, I have managed to develop my own tool that can work perfectly on all types of files and all size of data. The tool is called "**Stego Magic**". You can download it from the following link.

[Download StegoMagic.zip](#)

The zip file contains two versions of *Stego Magic*: One for encrypting the text messages and the other for encrypting binary files. *StegoMagic_TXT* can be used to hide text messages in other files such as an image or a sound file. *StegoMagic_BIN* can be used to hide one binary file in another such as an executable file inside an image or an image inside a video file.

With *Stego Magic*, there is no limitation on the size and type of the file that you are intending to hide. For example, you can hide a video of size 1 GB in an image of size 1 MB or hide an executable file inside a WORD document.

The tool is pretty straightforward to use and requires no special understanding of the concept.

At the end of the encryption process, a secret decryption key will be generated and the same is required during the decryption process.

How to Use Stego Magic?

Suppose you want to hide a text message inside a JPG file:

Place the JPG and the text file (.txt) in the same folder as that of *StegoMagic_TXT.exe*

- Run *StegoMagic_TXT.exe* and follow the screen instructions to embed the text message inside the JPG image.
- Please note that if you're using Windows 7/Vista, right-click the file and select "Run as Administrator". Otherwise the tool may fail to work properly.
- Note down the *secret decryption key*.
- Now you can send this image to your friend via email. To decrypt the hidden message, your friend should load this JPG file onto the *Stego Magic* tool and use the *secret decryption key*.
- I hope you've now understood what is steganography and how to use it to hide your secret data. For queries and feedback, please pass your comments.

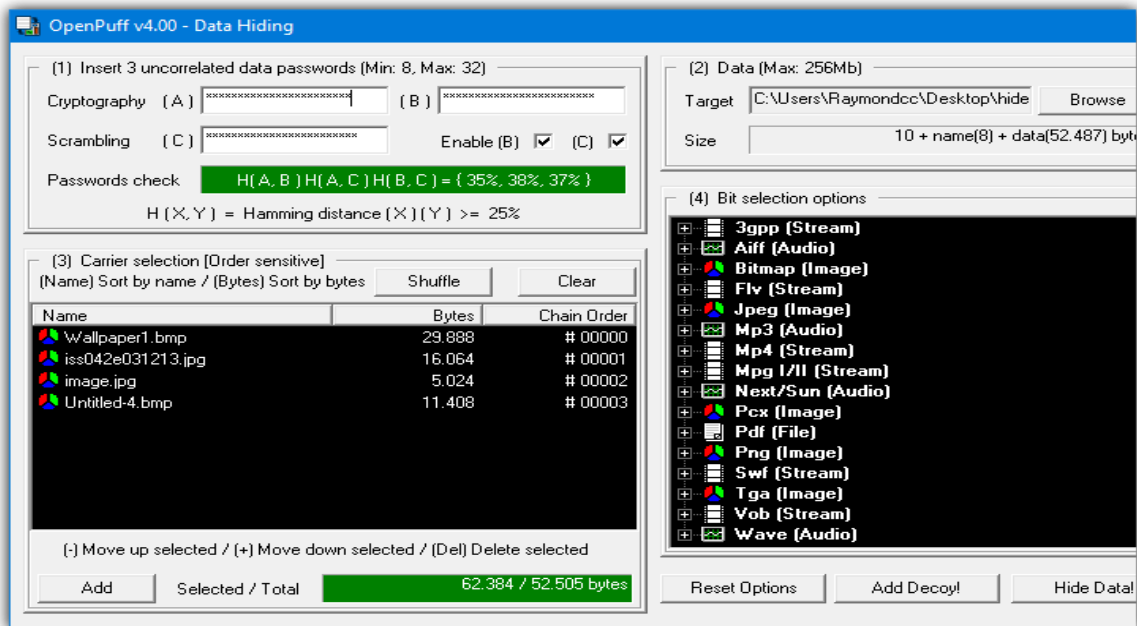
7 Free Ways to Hide a File or Message Inside Another File

Apart from password protecting data with an archiver or an [encryption tool like VeraCrypt](#), another effective way of securing your files is hiding them inside other files so nobody actually knows they exist. The practice of hiding data inside other data has amazingly been around for thousands of years and is called Steganography. With computer based steganography, you can hide messages, text files, archives and almost any type of data inside images, audio files, video files, and etc.

There are also varying levels of security for steganography on your computer. These range from simply [appending one file to another](#) to full on encryption, compression, and obfuscation. If you are sending files containing hidden data to others, the recipients would need to know how to retrieve it, such as knowing passwords and the software used. Here are 7 ways to perform steganography from your PC, all were tested on Windows 7 and 10 64-bit.

1. OpenPuff

OpenPuff is one of the few steganography tools that is relatively up to date. Many other tools work fine but were abandoned years ago. It's also a more complicated and a far more advanced program than the others here. OpenPuff is probably the most powerful free steganography tool around, it also doesn't need installing and is completely portable.



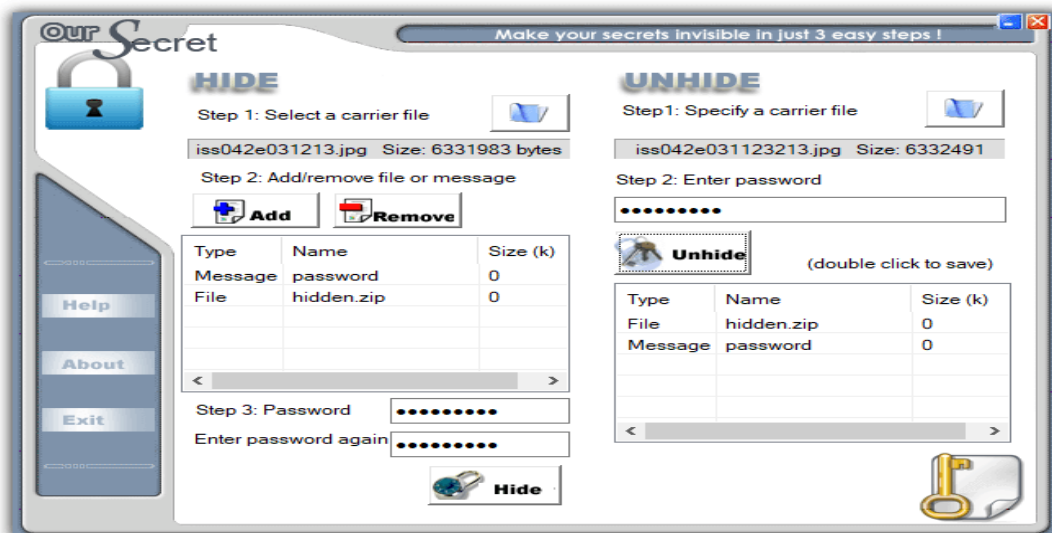
The steps to hide a file are numbered 1 – 4. By default, OpenPuff requires three separate passwords to encrypt the data. This can be reduced to two or a single password by unchecking the boxes. At step 2 browse for any type of file to hide and then at step 3 add a carrier file. Sixteen file formats are supported including MP4, MP3, MPEG2, PDF, FLV, VOB and common image and audio files.

You can also spread the hidden data file across several different carrier files, just add as many as you need (add more if the bar is red). For added security, a decoy file can even be used which will unhide the decoy instead of the real hidden data if someone actually knew how to unlock your file. The Step 4 Bit Select options are probably best left alone unless you read up on how they work. To unhide the data file you have to supply all the passwords and put the carrier files in the correct order. OpenPuff also includes a marking feature which is useful for digitally watermarking or copyrighting your own files.

2. Our Secret

Our Secret has been discontinued and the website is now gone. However, the program itself still works fine in the latest Windows. Use the portable standalone executable link provided below as the official installer elsewhere on the internet no longer works. The last version of Our Secret was 2.5 from 2012. Hiding files in Our Secret is set out in three distinct steps. Firstly, browse for the file to carry the hidden data. The good thing is this can be any type of file you like, but obviously, small or text based files are not going to work too well. At the next step, pressing **Add** will give the option of entering plain text or browsing for a file to hide, a mixture and multiple entries can be included. Enter a password and finally press the **Hide** button.

Unhiding data is done from the main window and is simply a reversal of hiding. Specify the carrier file, enter the optional password and any hidden files or text will appear in the box. Double click the entry to save the file or view the text and then optionally save as a text file.



3. SilentEye

While SilentEye looks very easy to use when you first launch it, things get more advanced during the process of embedding the data in the carrier file. It's not too difficult though and the average user can leave most settings they don't understand at the defaults. The number of formats that can carry the hidden data is limited to JPG, PNG, BMP, TIFF and WAV but that should be enough for hiding small files and plain text messages. Simply drop a supported media file onto the main window and press **Encode**. The upper half of the encode window differs depending on whether you are using an image or audio file. The media options can be left alone if you are unsure what they do, just change the destination folder. Type a short message into the box or add any type of file by pressing the large button. Optional AES encryption is enabled by checking the box at the bottom and entering the password twice.

Drop the media file onto the window and press Decode if you want to retrieve the hidden data. Make sure to use the same options and password (if used) or the hidden data will not be extracted.

4. Clotho

Unfortunately, Clotho is another program that is no longer supported or updated. Like OurSecret, the last version is from 2012 but it does work fine when used in the latest Windows. To install this program make sure that you right click and run the setup installer as administrator. Alternatively, unpack the installer with 7Zip or [Universal Extractor](#) as only the Cloth.exe is required.

What makes Clotho interesting is you can select a complete folder full of files to hide in one go. Obviously, the carrier file has to be large enough to effectively hide a folder's worth of data. The interface is self-explanatory, select the file to use as the mask (carrier), select the file or folder to hide, choose a save as name and optional parameters and press **Pack**. Most common types of file can be used as a carrier, including image, audio, video, archive and executable.

The options include adding a password and/or encryption, compressing the output file, performing extra obfuscation methods and making the hidden file(s) extractable with WinRAR. None of those options are enabled by default. A useful unpack option is cleaning the source file of hidden data so it is restored back to a normal file.

Steganographic Encoder

This form uses steganography techniques to hide a secret message (or even another file) in a JPEG image, or a WAV or AU audio file. The changes to the file should be invisible to any casual observer. Once you submit, you should be prompted to save your modified file.

If the payload is too large, (more than about 10% the size of the image for small images, closer to 20% for larger images) this may fail silently. You may wish to find the capacity of the file below before embedding data in it.

Select a JPEG, AU or WAV file to upload:
 C:\Users\Raymondcc\Desktop\iss042e031213.jpg Browse...

Password (may be blank):
 123456789

Payload (select the appropriate radio button to either enter payload text directly or upload a file):
☒ Just find capacity of this file
☐ Text
 My Hidden Text
 for Raymond.cc
☐ File payload: Browse...

Submit Query

Once you've encoded, try to [decode a file](#), or [compare the differences](#) between your original file and the file you've just decoded.

These pages use the [steghide](#) program to perform steganography, and the files generated are fully compatible with steghide.

JPEG quality: 75%
 Header position: bottom
 Passphrase: ***** show

Destination: C:/Users/Raymondcc/
☒ use this location as default

Write a message or select a file to hide.

My password:
 123456789
 from Raymond.cc

OR

no file selected
remove file

Type: AES256 Key: [hex string]
 CharSet: UTF8 ☒ Enable encryption ☒ Compress data Cancel Encode

Clotho v2.4

Clotho::PACK Combine two different file, secretly hiding a file into the other file without damaging both files.

Pack Unpack Option

File As Mask:
 C:\song.mp3 Browse...

File/Folder to Hide:
 C:\Users\Raymondcc\Desktop\my_hidden_text.txt File Folder

Save as:
 C:\song_2.mp3 Browse...

Option
☒ Encrypt Data
 Encrypt the data for more security.
☒ Use Password
 Use password for better encryption.
 Set Password: hgdmyjfdysdy566sm6dr6s
☒ Compress Data
 Compress data to reduce result size.
☐ Obfuscate Data
 Scramble data bit without damaging it.
☐ Winrar Compatibility Mode
 Restructure data so it can be extracted with WinRAR.

Estimated Size
 18 KB

PACK

© 2011-2012 Henry Nugraha

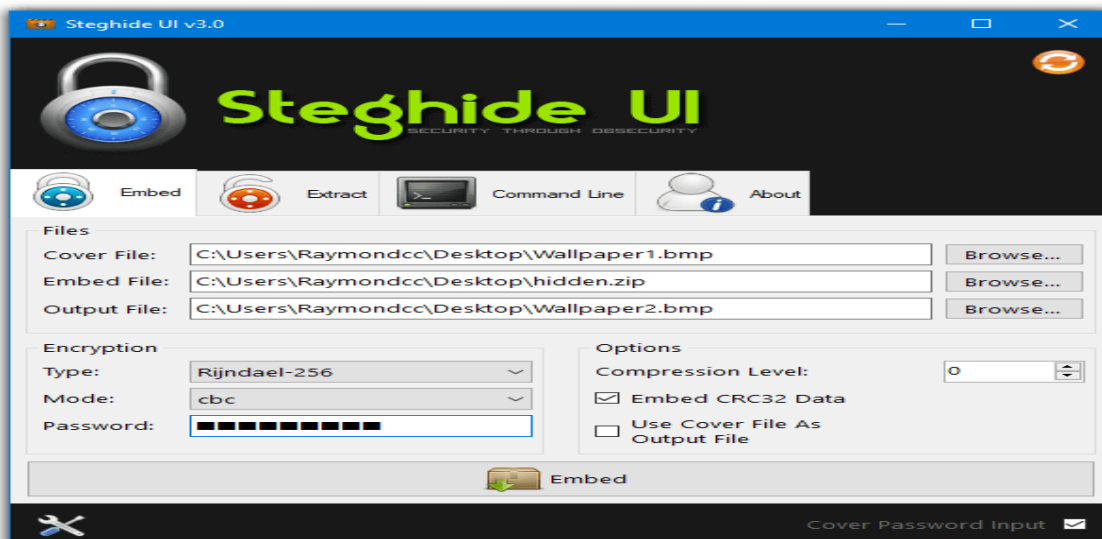
5. Steganography Tools (Online)

While the decoding process on the “Decode an image” page is mostly straightforward, it’s not too smart in knowing exactly what you encoded in the first place. If it was plain text, it’s easy. If it was something else like an archive you may have to rename the file correctly once downloaded. The Compare two images page shows before and after images side by side showing you roughly where on the image the hidden data is situated.

6. Steghide UI 3

Steghide UI is a user interface frontend for the same Steghide command line tool used on the webpage above. The Steghide tool itself hasn’t been updated since 2003 but this open source frontend program dates to 2011. Both work fine on the latest versions of Windows. Two image formats (JPG, BMP) and two audio formats (WAV, AU) are supported

The whole process is quite simple, browse for the Cover file (media file to hide the data in), browse for the embed file (the file to hide), choose an output location and filename. There are several password encryption types available although Rijndael 128/192/256 should be fine (commonly known as AES encryption). Optionally add a compression level of 1 – 9 to compress the embed file and finally press the **Embed** button.



Extracting the hidden data is very simple. Supply the media filename, the output filename and a password if the data was hidden using one. There is also a command line tab if you know how to use Steghide commands manually. The Options window can add a context menu entry into Explorer, set the default encryption type, compression level, and output folder.

7. Using Built-in Windows Commands

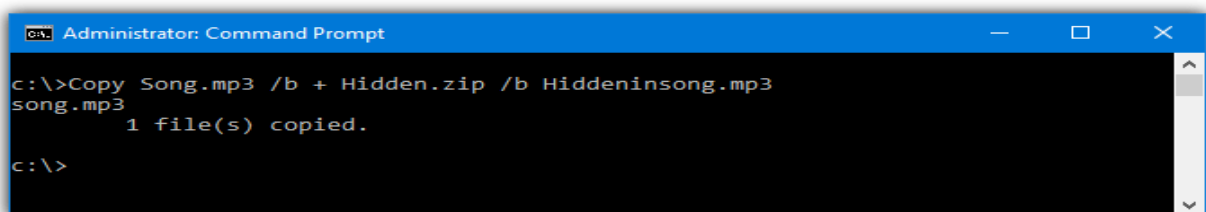
It's possible to perform simple steganography by using nothing more than the included tools found in Windows. While it's not the most secure method, the process works and no third party software is needed. Hiding data inside files this way is done through the Command prompt using the Windows Copy command. In addition to transfers, Copy can also join files together, which is how this process works. The hidden file is not encrypted or compressed by Copy, so you should archive the file to ZIP, 7ZIP or RAR first using a password. Then add that as the hidden file to the carrier file. The command syntax is as follows:

Copy Carrierfile /b + Hiddenfile /b Outputfile

The /b argument tells Copy it is dealing with binary files. As an example, to attach Hidden.zip to Song.mp3 and save a file called Hiddeninsong.mp3, you would use:

Copy Song.mp3 /b + Hidden.zip /b Hiddeninsong.mp3

The output file is playable in a music player like Windows Media Player, but the hidden file will also open in an [archiver such as 7-Zip or WinRAR](#) if you know the password.

A screenshot of a Windows Command Prompt window titled "Administrator: Command Prompt". The window has a blue title bar and a black background. The command prompt shows the following text: "c:\>Copy Song.mp3 /b + Hidden.zip /b Hiddeninsong.mp3", "song.mp3", and "1 file(s) copied.". The prompt "c:\>" is visible at the bottom left of the window.

```
Administrator: Command Prompt
c:\>Copy Song.mp3 /b + Hidden.zip /b Hiddeninsong.mp3
song.mp3
1 file(s) copied.
c:\>
```

How to Hack WhatsApp Account

How to hack WhatsApp in simple steps. Since WhatsApp has become one of



the popular app to share messages and media instantly, it has also become a favorite place for many to engage in illicit activities. Therefore, in order to investigate the truth people are left with no choice other than to hack WhatsApp account.

1. WhatsApp Hack using a Spying App: The Easiest Way

Even though there are several ways to hack WhatsApp, using a spy app is by far the most simple and easiest way. This method requires no prior hacking knowledge or technical skills to carry out and hence more suitable for common people. Installing a spy app to hack WhatsApp is as simple as installing any other app on mobile. Out of several apps out there, mSpy Premium is one of my favorite one to hack WhatsApp:



How to Hack WhatsApp with this App?

- Install the spy app on the target WhatsApp phone which takes a few minutes to complete.
- After this is done, the app silently records all WhatsApp conversation in hidden mode.
- All the WhatsApp chat records are sent to your online account.
- View all the information from anywhere at anytime with your online account.

mSpy Premium Features:

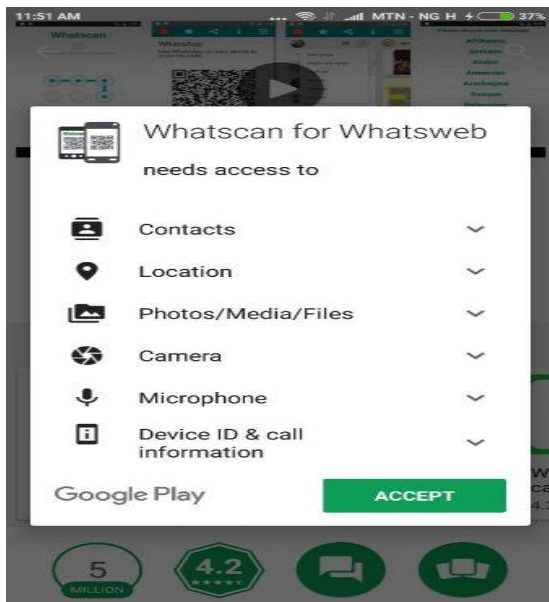
- Runs in **Hidden Mode** and remains **Undetected** on the target phone!
- Hack phone Calls and Text Messages.
- Hack WhatsApp, Skype and other popular messengers.
- Track Real-Time Location with GPS Tracker.
- Spy on Contact List and Web Browsing activities.
- Monitor Emails, Pictures and Videos.
- No Rooting Required!

2. How to Read Someone's Whatsapp Messages from your phone

Still thinking how you can read, download and send messages, pictures, videos even documents on someone else whatsapp account on your phone? think no more as i am about to show the easiest way to be able **read someone's whatsapp** chats.

To be able to *read someone's whatsapp* messages on your mobile just follow this 2 easy steps:

Step 1: Install and Setup Whatscan for whatsweb



- You will need to download and install Whatscan app on your device, it is available for both Android and IOS.
 1. [Android Version](#)
 2. [IOS Version](#)
- Open the app on your phone and select your language, that's all.

Step 2: Scan QR code on Whatscan with your victimswhatsapp

- This is the part where you will have to get hold of your victims phone physically to scan the QR code generated by the app. So get your victims phone open their whatsapp and use it to scan the QR code on the Whatscan app on your phone.

1. Android: Open Whatsapp> Menu >WhatsApp Web
 2. iPhone:OpenWhatsApp> Settings >WhatsApp Web
 3. Windows Phone: Open WhatsApp> Menu >WhatsApp Web
- After scanning the QR Code, Whatscan will now display your victims whatsapp, you can now do all you want on your phone with your victims WhatsApp account like:
 - Read messages
 - Send messages
 - Change profile picture
 - Change Profile status
 - Send voice note
 - Download galleries, files etc to your phone and lots more.

You can choose to secure your Whatscan app using a password.

Now you can see how easy it is to **read someone's whatsapp** chat on your phone, share with friends!



Hack Friend's WhatsApp with these Simple Tricks You just need the WhatsApp number you want to hack and spy on and you are there! Here's

how any and every iOS and Android smartphone users can try these free and online tricks to hack any WhatsApp account in less than 5 min. WhatsApp group admins can restrict members from sending messages.

STEP 1:

Go to your phone's app store and download WhatsApp Sniffer & Spy Tool 2016 How to Check Someone's WhatsApp Messages Without Touching their Phone

STEP 2:

Open the app, enter the person's number, whose account you wish to hack



STEP 3:

Wait for 2-3 min for the hacking to be processed and then click on 'Verify option'

STEP 4:

Now you can get access to your friend's messages, images, videos, or any other information that he has stored over the last 30 days instantly. WhatsApp to update its privacy policy prior Payments launch in India Get ready for some interesting and exciting read!



Prevent Your Phone From Hacking | Android Secret Codes

Today I share with you some codes to check and prevent your android device from hacking: Data is the most important factor of everyone's life. No one does want that his/her personal data are gone in wrong hands. In today's world, where technology is becoming more and more advanced. Where its latest cracks and vulnerabilities are also introduced daily. We also download many applications in our Android phones. Some are from authentic sources and some are from unauthentic sources, where the risk of malwares and breach of personal data are becoming 90%. Because the attackers attach malicious files with pirated softwares and when the user downloads it. The attackers make control on their victim device and transfer all personal data to their devices.